

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

14 February 2018

EXERCISE NO. 1

#marks: 10

- (1) Describe the Diffie-Hellman protocol
- (2) Argue about its security w.r.t. a passive adversary
- (3) Argue about its security w.r.t. a MITM attack

EXERCISE NO. 2

#marks: 10

A client C and server S share a password P . Furthermore, C knows the public key PK_S of the server S to be used in an asymmetric encryption scheme. Finally, client and server clocks are not synchronized.

1. Design a protocol that makes it possible to establish a session key K_s between the client and the server to be used in a symmetric scheme. The protocol must satisfy the key authentication and key confirmation properties.
2. Analyse the protocol by means of the BAN logic and specify the assumptions under which the protocol works.

EXERCISE NO. 3

#marks: 10

Tell whether the following statements are true or not. Argue the answer.

1. A Vernam cipher (aka One Time Pad) is unconditionally secure provided its key is at least 64 bits.
2. In a computationally secure cipher, the key must be at least 64 bits.
3. Let E be a cipher with $n = 128$ and $k = 64$, then E is unconditionally secure.
4. Let E be a cipher with $n = 128$ and $k = 128$, then E is computationally secure.
5. An unconditionally secure cipher is also computationally secure.

SOLUZIONE

Exercise n.1

See theory

Exercise n.2

The protocol consists of the following steps

M1 $S \rightarrow C: n_s$

M2 $C \rightarrow S: \mathcal{E}_{PK_S}(P, k_{cs}, n_s, n_c)$

M3 $S \rightarrow C: E_{k_{cs}}(S, C, n_c)$

Exercise n.3

1 A Vernan cipher is unconditionally secure provided its key is at least 64 bits.

FALSE. A Vernam cipher is unconditionally secure if: 1) keys are as long as the plaintext; 2) keys are truly random; 3) all plaintext has the same length; 4) any plaintext has a non-null probability.

2. In a computationally secure cipher, the key must be at least 64 bits.

TRUE. In a computationally secure cipher brute force attack is the most effective option for an adversary. To prevent this attack, the key space must be adequately large. Nowadays this means that the key length must be at least 64 bits.

3. Let E be a cipher with $n = 128$ and $k = 64$. E is unconditionally secure.

FALSE. E is certainly not unconditionally secure because, according to the Shannon's theorem, the key size is smaller than the plaintext size.

4. Let E be a cipher with $n = 128$ and $k = 128$. E is computationally secure.

FALSE. These assumptions are not sufficient to deduce that a cipher is computationally secure.

5. An unconditionally secure cipher is also computationally secure.

TRUE. An unconditionally secure cipher is secure regardless the adversary's computing power.

Domande Orale:

- Cifratura Multipla: 3DES, complessità rispetto a 2DES (MiTM)
- Kerberos e il problema della delega
- RSA e la scelta del parametro pubblico e (partire da Square and Multiply)
- Protocollo Handshake (in maniera molto generale, vuole sapere cosa si dicono client/server senza andare nello specifico)
- ECB/CBC

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

18 February 2014

NAME _____ SERIAL NO. _____

EXERCISE NO. 1

#MARKS: 12

Define a secure hash function and argue the relevance of its properties with respect to digital signature.

EXERCISE NO. 2

#MARKS: 6

In an access control system (ACS), Alice brings a personal device that is equipped with a symmetric cypher, a collision-resistant hash function, a random number generator, and a short-range wireless communication device. Alice and the ACS share a password Π_A .

Design a challenge-response protocol that allows Alice to prove ACS her presence. The key K_A shared by Alice and ACS for the challenge response protocol is derived from the password. The protocol must i) guarantee the authentication of Alice; ii) be resistant to replay-attacks; and iii) prevent offline password-guessing attack.

EXERCISE NO. 3

#marks: 12

Let (S, D) be a secure digital signature scheme with appendix. Let S and D be the signature and verification algorithm, respectively. Furthermore, let K_P be principal P 's public key, and CA a Certification Authority that is trusted by all principals of the system. Finally let H be a secure hash function. Which of the following *certificates* are useful to establish a secure channel with Alice? Argue why.¹

- (A) "Alice" $\parallel K_A \parallel S_{CA}(Alice)$
- (B) "Alice" $\parallel K_A \parallel S_{CA}(K_A)$
- (C) "Alice" $\parallel K_A \parallel S_A(H("Alice" \parallel K_A))$
- (D) "Alice" $\parallel K_A \parallel S_{CA}("Alice" \parallel H(K_A))$
- (E) "Alice" $\parallel K_A \parallel S_{CA}(H("Alice" \parallel K_A))$
- (F) "Alice" $\parallel K_A \parallel S_{Bob}("Alice" \parallel K_A) \parallel "Bob" \parallel K_B \parallel S_{CA}("Bob" \parallel K_B)$
- (G) "Alice" $\parallel K_A \parallel S_{Bob}("Alice" \parallel K_A) \parallel "Bob, CA: yes" \parallel K_B \parallel S_{CA}("Bob, CA: yes" \parallel K_B)$.

¹ Neglect any issue related to time.

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

29 January 2014

SOLUTION

EXERCISE #1

See theory.

EXERCISE #2.

$$M1 \quad A \rightarrow S: \quad A$$

$$M2 \quad S \rightarrow A: \quad n_s$$

$$M3 \quad A \rightarrow S: \quad E_{K_A}(A, n_s, s_A)$$

where $K_A = h(\Pi_A)|_k$. Notice that s_A is a random salting quantity aimed at avoiding an offline password-guessing attack.

EXERCISE #3.

- A. Certificate A does not link KA to Alice
- B. Certificate A does not link KA to Alice
- C. Certificate B is self-signed and Alice is not a trusted authority
- D. Certificate C is fine.
- E. Certificate C is fine.
- F. Bob, who is not a trusted authority, signed certificate D.
- G. Certificate E is fine: CA delegates B to sign certificates.

Prova scritta del 10 gennaio 2007 (5 punti)

Testo

Sia PK la *chiave pubblica* del server S e sia PIN un *segreto condiviso* tra il server S ed il cliente C . Si definisca un protocollo di distribuzione delle chiavi che, al termine della sua esecuzione, soddisfi i seguenti requisiti:

1. il cliente ed il server condividono una *chiave segreta di sessione* K ;
2. il cliente ha identificato il server ed ha la prova che il server possiede la chiave K ;
3. il server ha identificato il cliente ed ha la prova che il cliente possiede la chiave K ;
4. il protocollo è resistente ad attacchi di *replay*.

Tali requisiti devono essere soddisfatti in presenza del seguente vincolo: per quanto riguarda la crittografia a chiave pubblica, il server ed il cliente dispongono solo di un cifrario (in altre parole la firma digitale non è disponibile).

Soluzione

Un protocollo che soddisfa i requisiti è il seguente

M1 $S \rightarrow C: S, C, n$
M2 $C \rightarrow S: C, S, E_{PK}(C, S, PIN, K, n)$
M3 $S \rightarrow C: S, C, E_K(S, C, n);$

La chiave è un segreto condiviso tra cliente e server perchè in rete essa appare sempre nella sua forma cifrata.

Il cliente identifica il server alla ricezione del messaggio M3 perchè tale messaggio è cifrato con la chiave K . Siccome questa chiave è stata trasmessa nel messaggio M2 in forma cifrata per mezzo della chiave pubblica del server PK , allora solo il server può aver decifrato il messaggio M2 e originato il messaggio M3. Il server dà perciò prova al cliente di possedere la chiave K cifrando il messaggio M3 con tale chiave.

Dalla presenza del PIN nel messaggio M2, il server deduce che il mittente è il cliente e che questo possiede la chiave K .

Se n è una quantità “fresca”, allora il server ha la possibilità di determinare se M2 è un replay oppure no. Se la chiave K è fresca (come deve essere una chiave di sessione), il cliente ha la possibilità di determinare se M3 è un replay oppure no.

Commento. L'utilizzo del PIN come chiave di cifratura non è da considerarsi una idea valida perchè non si riesce a fornire un adeguato compromesso tra sicurezza ed usabilità. Un PIN deve essere facilmente ricordabile da un umano, quindi avrà “pochi bit” e quindi non sarà una “buona” chiave. Un PIN usabile come chiave avrà “troppi” bit per poter essere “facilmente” ricordato da un umano.

ESERCIZIO DI SICUREZZA [6 PUNTI]

Quesito 1. Il candidato dia la definizione delle proprietà *preimage resistance*, *second-preimage resistance* e *collision-resistance* di una funzione hash.

Le funzioni hash sono utilizzate nelle *one-time password* (OTP), una tecnica che permette ad un utente di identificarsi ad un server attraverso un terminale inaffidabile.

Setup

1. L'utente U sceglie un numero random segreto s .
2. L'utente calcola $n+1$ password come segue: $P_n = h(s)$, $P_{n-1} = h(P_n) = h^2(s)$, ..., $P_1 = h(P_2) = h^n(s)$, $P_0 = h(P_1) = h^{n+1}(s)$.
3. L'utente distribuisce la password P_0 al server S con metodi off-line in modo però da garantirne l'autenticità.

Utilizzo

1. Alla i -esima identificazione, $1 \leq i \leq n$, l'utente si identifica inviando al server S la password P_i .
2. Alla ricezione di P_i , il server verifica se $P_{i-1} = h(P_i)$. In tal caso l'identificazione ha esito positivo; negativo altrimenti.

Quesito 2. Il candidato indichi, motivando la risposta, di quali proprietà è sufficiente che goda la funzione hash h per un utilizzo in uno schema OTP.

Quesito 3. Il candidato indichi, motivando la risposta, quale tipo di avversario (attivo o passivo) uno schema OTP permette di contrastare.

SOLUZIONE

Quesito 1.

La risposta è nel lucido 10 del blocco di lucidi relativo alle funzioni hash (<http://www2.ing.unipi.it/~d8333/Teaching/SeminarioSnR/materiale/Funzioni-Hash.pdf>).

Quesito 2.

La funzione deve soddisfare le proprietà di preimage resistance (*one-way*) e di 2nd-preimage resistance (*weak collision resistance*). Se le proprietà non fossero soddisfatte, un avversario potrebbe intercettare una password e calcolare tutte le pre-immagini ricostruendo così la catena delle password.

Quesito 3.

OTP permette di contrastare un avversario passivo. Un avversario attivo può aggirare OTO con un attacco del tipo *man-in-the-middle*.

RETI DI CALCOLATORI

Appello del 17 luglio 2007

ESERCIZIO DI SECURITY

PUNTI: 6

Il candidato definisca un protocollo di distribuzione delle chiavi che, al termine della sua esecuzione, soddisfi i seguenti requisiti:

1. Alice e Bob condividono una chiave segreta di sessione K ;
2. Alice ha la prova che Bob dispone della chiave K e viceversa;
3. il protocollo è resistente ad attacchi di replay.

Tali requisiti devono essere soddisfatti assumendo i seguenti vincoli

- A. Alice e Bob dispongano *solo* di un cifrario asimmetrico (no firma digitale);
- B. Alice (Bob) conosce e_b (e_a) la chiave pubblica di Bob (Alice);
- C. la chiave di sessione viene definita da Alice.

Si indichi con: (i) $E_e(X)$ la cifratura della quantità X con la *chiave pubblica* e ; (ii) (X, Y) la concatenazione di X ed Y .

Il candidato dimostri brevemente, ma con precisione e proprietà di linguaggio, che il protocollo proposto soddisfa i requisiti specificando sotto quali ipotesi ciò avviene.

SICUREZZA NELLE RETI

Appello del 1 Febbraio 2007

Soluzione

Messaggio M1 $A \rightarrow B: \{A, B, K\}_{e_b}$

Messaggio M2 $B \rightarrow A: \{\{A, B\}_K, A, B, n_b\}_{e_a}$

Messaggio M3 $A \rightarrow B: \{A, B, n_b\}_K$

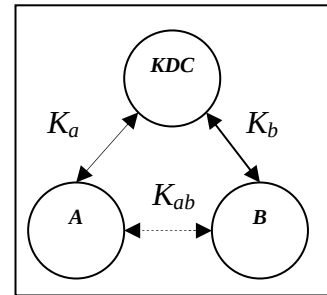
Dopo la ricezione di M1, B non può dire niente.

Dopo la ricezione di M2, A può concludere che il messaggio viene da B e quindi che B detiene la chiave K perché la parte interna è cifrata con K. Inoltre conclude che il messaggio non è un replay perché la chiave K è fresca.

Dopo M3, B può concludere che il messaggio proviene da A perché solo A può aver decifrato M2 e inserito n_b in M3 che, a tutti gli effetti, è un segreto condiviso. La cifratura con K prova a B che A detiene tale chiave.

Esercizio 2

A e B devono stabilire una chiave di sessione K_{ab} da utilizzare con un cifrario (E, D). A tale scopo A e B utilizzano il protocollo di Diffie-Hellman (DH), con parametri pubblici p e g . Per evitare l'attacco dell'uomo nel mezzo, il protocollo DH viene esteso per mezzo di un Key Distribution Center (KDC), on-line, con cui A e B condividono una chiave simmetrica, rispettivamente, K_a e K_b .



Quesito 1. Progettare il protocollo DH-esteso (E-DHP) in modo che soddisfi i seguenti requisiti: a) il protocollo non è soggetto all'uomo nel mezzo; b) al termine del protocollo, A ha la prova che B dispone di K_{ab} e viceversa.

Quesito 2. Valutare se nell'interazione tra A, B e KDC è possibile sostituire il cifrario (E, D) con un *message authentication code* $h_K()$.

Quesito 3. Si assuma che un avversario disponga di una K_{ab} passata ed abbia registrato tutti i messaggi che hanno portato a stabilirla. Tramite un replay attack, l'avversario può indurre A (o B) a stabilire ancora K_{ab} come chiave condivisa? Motivare la risposta.

Soluzione

Quesito 1.

A → KDC: A, B, {A, B, X_a } K_a
KDC → A: A, B, {A, B, X_a } K_b
B → KDC: B, A, {B, A, X_b } K_b
KDC → A: B, A, {B, A, X_b } K_a
A → B: {A} K_{ab}
B → A: {B} K_{ab}

Quesito 2

{Z} K_x può essere sostituito con $h_{K_x}(Z)$

Quesito 3. No, l'avversario non può indurre A (o B) a stabilire ancora K_{ab} . Infatti il protocollo DH richiede che ad ogni istanza di esecuzione, ciascuno dei peer generi una nuova chiave segreta in modo random. Per cui, anche se l'avversario riusa X_b , A genererà una nuova chiave segreta a' e perciò l'a nuova chiave sarebbe kba' . Per poter stabilire tale chiave l'avversario dovrebbe ricavare b da X_b ma ciò richiede di risolvere il DLP.

Prova scritta del 24 giugno 2008 (10 pt)

Si consideri il seguente protocollo di identificazione di tipo challenge-response basato sulla crittografia a chiave pubblica.

M1 $A \rightarrow B: A$

M2 $B \rightarrow A: E(e_A, r)$

M3 $A \rightarrow B: r$

Dove $E(e, x)$ denota la cifratura di x con la chiave pubblica e (quindi E è *asimmetrico*) ed r è una quantità generata per mezzo di un generatore sicuro di numeri random. Si assuma che B conosca e_A , la chiave pubblica di A .

1. Al termine dell'esecuzione del protocollo quali garanzie, B può concludere di essere in presenza di A ? Motivare la risposta.
2. Nel protocollo è possibile generare la quantità r per mezzo di un semplice contatore senza indebolire il protocollo?
3. Riprogettare il protocollo sotto le seguenti ipotesi: 1) A e B utilizzano adesso un cifrario simmetrico E_s ; 2) A e B condividono una chiave segreta k_{AB} ; 3) né A né B dispongono di un generatore random sicuro

Soluzione

Domanda 1. Il processo B è convinto che il messaggio $M3$ proviene da A perché solo A può aver decifrato il contenuto del messaggio $M2$. Inoltre, siccome B considera r fresco, allora ritiene che il messaggio $M3$ non sia una replica di un vecchio messaggio. Per cui alla fine del protocollo, B ritiene di star effettivamente parlando con A .

Domanda 2. Il generatore sicuro di numeri random non può essere sostituito da un contatore. Il numero r , oltre alla proprietà di freschezza (mai utilizzato in precedenti esecuzioni) deve anche godere della proprietà di *imprevedibilità*. Altrimenti, un avversario potrebbe prevedere il prossimo valore di r e costruire il messaggio $M3$ senza aver decifrato il contenuto $M2$. Così facendo l'avversario potrebbe impersonare A .

Domanda 3.

M1 $A \rightarrow B: A$

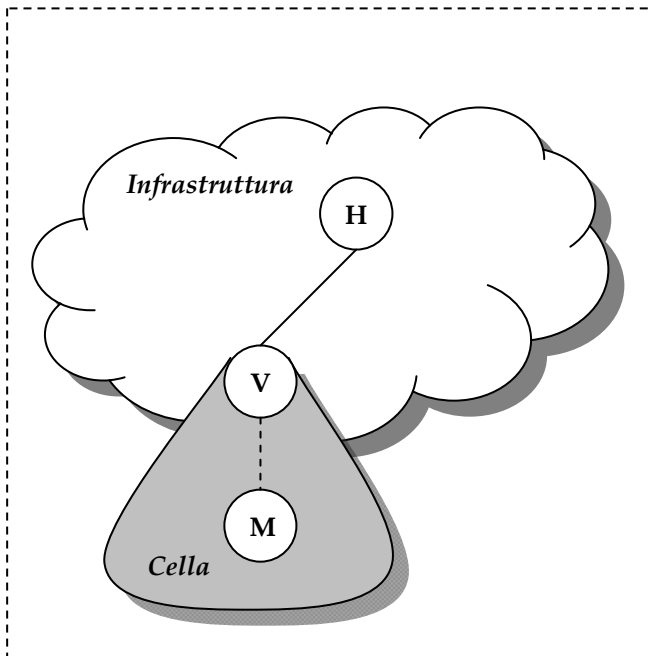
M2 $A \rightarrow B: r$

M3 $A \rightarrow B: E_s(k_{AB}, r)$

ESERCIZIO 2: Si consideri il sistema di *roaming* riportato in figura in cui una stazione mobile M , il cui *home server* è H , si trova in visita nella cella gestita dal server V . La stazione mobile M ed l'home server H condividono la chiave k_{mh} . I server H e V fanno parte dell'infrastruttura fissa e condividono la chiave k_{vh} . Progettare un protocollo che soddisfi i seguenti requisiti:

1. permette l'autenticazione mutua di M e V quando M entra nella cella V ;
2. permette di distribuire una chiave di sessione k_{mv} tra M e V ;
3. fornisce la prova a V che M possiede k_{mv} e viceversa;
4. mantiene la segretezza della chiave k_{mh} ;
5. è resistente ad attacchi di replay.

Si assuma che M , H , V utilizzino lo stesso cifrario e che i loro clock non siano sincronizzati. Il candidato argomenti brevemente ed informalmente, ma con precisione matematica e proprietà di linguaggi, che il protocollo proposto soddisfa i requisiti posti.



Soluzione

Nella soluzione indichiamo con $E(k, m)$ la cifratura del messaggio m con la chiave k e con $a \parallel b$ la concatenazione della quantità a con la quantità b .

1. $M \rightarrow V$: A, n_m
2. $V \rightarrow H$: A, n_m, n_v
3. $H \rightarrow V$: $E(k_{hm}, V \parallel n_m \parallel k), E(k_{hv}, A \parallel n_v \parallel n_m \parallel k)$
4. $V \rightarrow M$: $E(k_{hm}, V \parallel n_m \parallel n_v \parallel k), E(k, V \parallel M \parallel n_m)$
5. $M \rightarrow V$: $E(k, M \parallel V \parallel n_v + 1)$

PROVA SCRITTA DEL 13 GENNAIO 2009
10 PUNTI

TESTO

Si assuma che A e B abbiano gli orologi sincronizzati con un errore massimo pari a δ e che condividano una chiave segreta a lungo termine K .

Si consideri il seguente protocollo tramite il quale B invia una chiave di sessione K_{ab} ad A

M1 $A \rightarrow B$: A

M2 $B \rightarrow A$: $\{A, B, K_{ab}, T_b\}_K$

M3 $A \rightarrow B$: $\{A, B, T_b\}_{K_{ab}}$

Dove $\{\cdot\}$ denota un cifrario sicuro dal punto di vista computazionale e T_b è una marca temporale prelevata dall'orologio di B . Si assuma che B generi una chiave di sessione perfettamente random. Si assuma infine che A consideri M2 fresco se e solo se M2 è stato trasmesso entro una finestra temporale W , ovvero se $T_a - T_b < W$, con T_a istante di ricezione di M2 da parte di A .

1. Si risponda, motivando le risposte, alle seguenti domande
 - a. Il protocollo garantisce la confidenzialità della chiave di sessione?
 - b. Alla fine del protocollo, A ha la garanzia che K_{ab} proviene proprio da B e che è fresca?
 - c. Alla fine del protocollo, B ha la garanzia che A dispone della chiave K_{ab} ?
2. Sapendo che rtt è il round-trip-time medio e che t_e è il tempo di elaborazione medio di elaborazione del messaggio M2, si determini W_m , il valore minimo per W .
3. Si discuta qualitativamente qual è il rapporto tra disponibilità e sicurezza nei seguenti casi estremi:
 - a. W piccolo: $W \rightarrow W_m$
 - b. W grande: $W \rightarrow \infty$. (suggerimento: si assuma che un avversario sia riuscito a compromettere una chiave di sessione K_{ab} ed a registrare i messaggi M1–M3 corrispondenti).

SOLUZIONE

1.a. Il protocollo garantisce la confidenzialità della chiave di sessione perché la chiave di sessione è trasmessa in rete in forma cifrata.

1.b. A ha la garanzia che K_{ab} proviene da B perché è stata cifrata con K. Se M2 sta all'interno della finestra temporale, A ha la garanzia che il messaggio è fresco.

1.c. B ha la garanzia che A dispone della chiave perché B vede del materiale fresco cifrato con la chiave K_{ab} .

2. $W_m = rtt/2 + t_e + \delta$.

3.a. Nel caso in cui W sia molto vicino a W_m , aumenta la probabilità che il messaggio M2 non sia riconosciuto come fresco e che quindi il protocollo di distribuzione delle chiavi termini senza successo.

3.b Nel caso in cui W sia molto grande, se un avversario ha compromesso la chiave K_{ab} ed ha registrato il messaggio M2 corrispondente, allora può impersonare B rispetto ad A ed indurre A a riutilizzare la chiave K_{ab} semplicemente ritrasmettendo (replay) il messaggio M2. Questo attacco è tanto più possibile quanto più W è grande.

Perciò, un piccolo valore di W diminuisce la probabilità di un attacco di replay ma diminuisce la disponibilità del servizio. Al contrario un alto valore di W aumenta la disponibilità del servizio ma aumenta anche la probabilità di replay.

PROVA SCRITTA DEL 30 GENNAIO 2009
10 PUNTI

TESTO

Sia S un server e sia Π la sua chiave pubblica. Sia C un client che condivide con S un PIN P di 4 cifre decimali. Si assuma che C conosca la chiave pubblica Π del server. Si assuma inoltre che il client ed il server dispongano solo di un cifrario a chiave simmetrica e di uno a chiave pubblica.

Quesito 1. Il candidato progetti un protocollo che permetta al server di identificare il cliente, ovvero alla fine del protocollo il server deve avere prova di essere in presenza del cliente. Il protocollo deve essere sicuro rispetto ad un brute-force attack sullo spazio dei messaggi.

Quesito 2. Il candidato progetti un protocollo di distribuzione delle chiavi tra S e C che soddisfi i seguenti requisiti:

1. alla fine del protocollo C ed S dispongono della chiave di sessione K ;
2. alla fine del protocollo, C ha la certezza che S dispone della chiave K e viceversa.

SOLUZIONE

Quesito 1.

M1 $S \rightarrow C: n$

M2 $C \rightarrow S: E_{\pi_s}(C, S, P, n, \rho)$

Dopo la ricezione del messaggio M2, S pensa che il messaggio provenga da C perché contiene P ; S ritiene tale messaggio fresco perché contiene n .

Il sale ρ è necessario per evitare un attacco esaustivo sullo spazio dei messaggi. Infatti, a parte ρ tutte le quantità, inclusa la chiave pubblica, sono note eccetto il PIN. Perciò se ρ non ci fosse, siccome i pin sono solo 10 mila, l'avversario potrebbe eseguire un attacco esaustivo cercando quel valore di x per cui $M2 = E_{\pi_s}(C, S, x, n)$.

Quesito 2.

M1 $S \rightarrow C: n$

M2 $C \rightarrow S: E_{\pi_s}(C, S, P, n, K)$

M3 $S \rightarrow C: E_K(C, S)$

Dopo la ricezione del messaggio M2, S pensa che la chiave K proviene da C perché combinata con P e che è fresca perché combinata con n .

Dopo la ricezione di M3, C ha la garanzia che S dispone della chiave di sessione K perché solo S può aver decifrato K .

Prova scritta del 20 febbraio 2008 (10 pt)

Si consideri il seguente protocollo di identificazione di tipo challenge-response basato sulla crittografia a chiave pubblica.

M1 $A \rightarrow B: A$

M2 $B \rightarrow A: E_A(r)$

M3 $A \rightarrow B: r$

Dove $E_A(r)$ denota la cifratura di r con la chiave pubblica di A e r una quantità generata per mezzo di un generatore sicuro di numeri random. Si assuma che B conosca la chiave pubblica di A .

Il candidato risponda ai seguenti quesiti motivando le risposte.

- 1) Al termine dell'esecuzione del protocollo quali prove ha B di essere in presenza di A ?
- 2) Nel protocollo è possibile generare la quantità r per mezzo di un semplice contatore senza indebolire il protocollo?
- 3) Riprogettare il protocollo sotto le seguenti ipotesi:
 - a. A e B utilizzano solo un cifrario simmetrico E ;
 - b. A e B condividono una chiave segreta k_{ab} ;
 - c. né A né B dispongono di un generatore random sicuro

Soluzione

Domanda 1. Il processo B è convinto che il messaggio M3 proviene da A perché solo A può aver decifrato il contenuto del messaggio M2. Inoltre, siccome B considera r fresco, allora ritiene che il messaggio M3 non sia una replica di un vecchio messaggio. Per cui alla fine del protocollo, B ritiene di essere in presenza di A.

Domanda 2. Il generatore sicuro di numeri random non può essere sostituito da un contatore. Il numero r , oltre alla proprietà di freschezza (mai utilizzato in precedenti esecuzioni) deve anche godere della proprietà di *imprevedibilità*. Altrimenti, un avversario potrebbe prevedere il prossimo valore di r e costruire il messaggio M3 senza aver decifrato il contenuto M2. Così facendo l'avversario potrebbe impersonare A.

Domanda 3.

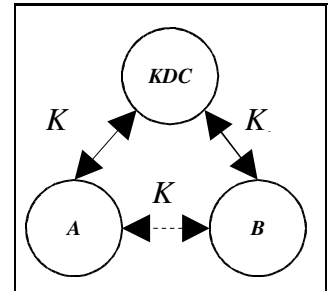
M1 $A \rightarrow B: A$

M2 $B \rightarrow A: r$

M3 $A \rightarrow B: E_{K_{ab}}(r)$

PROVA SCRITTA DEL 7 Luglio 2009 (10 PT)

A e B stabiliscono una chiave di sessione K_{ab} per mezzo del protocollo Diffie-Hellman (DHP), con parametri pubblici p e g . Per evitare l'attacco dell'uomo nel mezzo, il protocollo DH viene esteso per mezzo di un Key Distribution Center (KDC), on-line, con cui A e B condividono un cifrario simmetrico (E , D) ed una chiave simmetrica segreta. Siano K_a e K_b le chiavi simmetriche segrete che A e B condividono con KDC, rispettivamente.



Quesito 1. Progettare il protocollo DH-esteso (E-DHP) in modo che soddisfi i seguenti requisiti: a) il protocollo non è soggetto all'uomo nel mezzo; b) al termine del protocollo, A ha la prova che B dispone di K_{ab} e viceversa.

Quesito 2. Valutare se nell'interazione tra A , B e KDC è possibile sostituire il cifrario (E , D) con un *message authentication code* $h_K()$. Motivare la risposta.

Quesito 3. Si assuma che un avversario disponga di una K_{ab} passata ed abbia registrato tutti i messaggi dell'istanza di protocollo che l'ha stabilita. Tramite un replay attack, l'avversario può indurre A (o B) a stabilire ancora K_{ab} come chiave condivisa? Motivare la risposta.

Soluzione

Quesito 1 (4 pt)

M1 A → KDC: A, B, {A, B, Xa}K_a
M2 KDC → B: A, B, {A, B, Xa}K_b
M3 B → KDC: B, A, {B, A, Xb}K_b
M4 KDC → A: B, A, {B, A, Xb}K_a
M5 A → B: {A}K_{ab}
M6 B → A: {B}K_{ab}

Quesito 2 (3 pt)

{Z}K_x può essere sostituito con hK_x(Z)

Quesito 3 (3 pt)

No, l'avversario non può indurre A (o B) a stabilire ancora K_{ab}. Infatti, il protocollo DH richiede che ad ogni istanza di esecuzione, ciascuno dei peer generi una nuova chiave segreta in modo random. Per cui, anche se l'avversario riusa X_b, A genererà una nuova chiave segreta a' e perciò l'a nuova chiave sarebbe kba'. Per poter stabilire tale chiave l'avversario dovrebbe ricavare b da X_b ma ciò richiede di risolvere il DLP.

Esercizio 2

I processi A e B dispongono soltanto di un cifrario a chiave pubblica e di uno a chiave simmetrica. Si assuma che A conosca Π_B , la chiave pubblica di B, e viceversa. Supponendo che i clock non siano sincronizzati, progettare un protocollo di distribuzione delle chiavi che soddisfi i seguenti requisiti:

1. al termine dell'esecuzione del protocollo, il processo A ha la prova che il processo B dispone della chiave di sessione e viceversa;
2. il protocollo è resistente ad attacchi di replay;
3. la chiave di sessione è generata da uno dei due processi.

Modificare il protocollo assumendo che entrambi i processi contribuiscano alla generazione della chiave di sessione come segue: il processo A genera la quantità K_A , il processo B la quantità K_B e la chiave di sessione è data da $K_{AB} = f(K_A, K_B)$.

Soluzione

Protocollo 1.

$M1 \quad A \rightarrow B: \{K_a\}_{\Pi_b}$

$M2 \quad B \rightarrow A: \{K_a, K_{ab}\}_{\Pi_a}$

$M3 \quad A \rightarrow B: \{A, B\}_{K_{ab}}$

Protocollo 2

$M1 \quad A \rightarrow B: \{K_a\}_{\Pi_b}$

$M2 \quad B \rightarrow A: \{K_a, K_b\}_{\Pi_a}$

$M3 \quad A \rightarrow B: \{K_b, K_a\}_{\Pi_b}$

$M4 \quad B \rightarrow A: \{A, B\}_{K_{ab}}$

$M5 \quad A \rightarrow B: \{B, A\}_{K_{ab}}$

Nome e Cognome _____ Matricola _____

ESERCIZIO 1

punti:16

Con proprietà di linguaggio e precisione matematica, il candidato i) specifichi il protocollo di Diffie-Hellman; e ii) ne argomenti la sicurezza rispetto ad un avversario passivo. Inoltre, iii) estenda il protocollo DH al caso di n processi(Group-DH), iv) valutandone la complessità in termini di numero e dimensione dei messaggi trasmessi.

ESERCIZIO 2

punti: 6

Alice e Bob utilizzano il protocollo Diffie-Hellman (DH) per stabilire una chiave di sessione. Al fine di evitare l'attacco dell'uomo-nel-mezzo, Alice e Bob mantengono un segreto condiviso a-priori σ . Progettare e verificare con la logica BAN un protocollo il protocollo DH-modificato che utilizza tale segreto. La verifica può dirsi conclusa con successo quando si raggiungono i beliefs $B \models \overset{\vee}{\vdash}$ e $A \models \overset{\vee}{\vdash}$, con X_A ed X_B parametri pubblici di Alice e Bob, rispettivamente.

ESERCIZIO 3

punti:8

Con proprietà di linguaggio e precisione matematica, il candidato spieghi il problema del *keystream reuse* in WEP.

Soluzione

ESERCIZIO 1

Vedi appunti.

ESERCIZIO 2

- M1 $A \rightarrow n_A$
 M2 $B \rightarrow n_B$
 M3 $A \rightarrow h_{\sigma} \vee \parallel$
 M4 $B \rightarrow h_{\sigma} \vee \parallel$

IPOTESI

1. $A \models \vdash^v, B \models \vdash^v$
2. $B \models \Leftarrow^-, A \models \Leftarrow^-$
3. $A \models \dots, B \models \dots$
4. $A \models \Rightarrow \vdash^v, B \models \Rightarrow \vdash^v$

PROTOCOLLO IDEALIZZATO

- M3 $A \rightarrow \left. \begin{array}{c} / \vdash^v \\ \vdash^v \end{array} \right\} \sigma$
 M4 $B \rightarrow \left. \begin{array}{c} / \vdash^v \\ \vdash^v \end{array} \right\} \sigma$

TESI

1. $B \models \vdash^v, A \models \vdash^v$

ESERCIZIO 3

Vedi appunti.

Appello del 13 settembre 2011

NOME E COGNOME _____ MATRICOLA _____

ESERCIZIO 1

punti:10

Con proprietà di linguaggio e precisione matematica, il candidato i) descriva il protocollo *one-time pad* (OTP); ii) elenchi le ipotesi sotto le quali OTP è un cifrario ideale e ne discuta le implicazioni pratiche.

ESERCIZIO 2

punti: 10

Alice e Bob utilizzano il protocollo Diffie-Hellman (DH) per stabilire una chiave di sessione. Al fine di evitare l'attacco dell'uomo-nel-mezzo, Alice e Bob mantengono un segreto condiviso a-priori con un Key Distribution Center (KDC). Siano σ_A e σ_B i segreti di Alice e Bob rispettivamente. Supponendo che i clock siano sincronizzati, progettare e verificare con la logica BAN un protocollo DH-modificato che permette ad Alice e Bob di stabilire una chiave di sessione utilizzando il KDC. La verifica può dirsi conclusa con successo quando si raggiungono i beliefs $B \models \overset{X_A}{\mapsto} A$ e $A \models \overset{X_B}{\mapsto} B$, con X_A ed X_B parametri pubblici del protocollo DH di Alice e Bob, rispettivamente.

ESERCIZIO 3

punti:10

Con proprietà di linguaggio e precisione matematica, il candidato spieghi la vulnerabilità del protocollo di autenticazione di WEP.

Appello del 13 settembre 2011

NOME E COGNOME _____ MATRICOLA _____

Soluzione

ESERCIZIO 1

Vedi appunti.

ESERCIZIO 2

Per ipotesi le quantità σ_A e σ_B sono dei segreti condivisi e, come precisato in sede d'esame, in assenza di ipotesi ulteriori, non possono essere considerati chiavi di cifratura. Ad esempio, con riferimento all'algoritmo DES, un segreto potrebbe essere una *weak-key*. Quello che si può invece ragionevolmente supporre è che il segreto condiviso abbia una dimensione in bit adeguata a contrastare una ricerca esaustiva sebbene questo possa venire a detrimento dell'usabilità. Sulla base di queste considerazioni si può definire il seguente protocollo reale.

PROTOCOLLO REALE

$M \xrightarrow{K_D} A : X_A t_A h X_A t_A \sigma_A$
 $M \xrightarrow{K_D} B : X_B t_B h X_B t_B \sigma_B$
 $M \xrightarrow{K_D} B : X_A t_K h X_A t_K \sigma_B$
 $M \xrightarrow{K_D} A : X_B t_K h X_B t_K \sigma_A$

IPOTESI

1. $A \models \overset{X_A}{\mapsto} A, B \models \overset{X_B}{\mapsto} B$
2. $A \models \overset{\sigma_A}{\mapsto} A \xrightarrow{K_D} A, B \models \overset{\sigma_B}{\mapsto} B \xrightarrow{K_D} B$
3. $A \models \#(t_A), B \models \#(t_B), AB \models \#(t_K)$
4. $A \models B \xrightarrow{X_B} B, B \models A \xrightarrow{X_A} A$
5. $A \models \overset{X_B}{\mapsto} B \xrightarrow{K_D} B, B \models \overset{X_A}{\mapsto} A \xrightarrow{K_D} A$

PROTOCOLLO IDEALIZZATO

$$\begin{aligned} M1 \quad A \rightarrow KDC : & \quad \left\langle \begin{array}{c} x_A \\ \vdash A, t_A \end{array} \right\rangle_{\sigma_A} \\ M2 \quad B \rightarrow KDC & \quad \left\langle \begin{array}{c} x_B \\ \vdash B, t_B \end{array} \right\rangle_{\sigma_B} \\ M3 \quad KDC \rightarrow B & \quad \left\langle A \mid \vdash \begin{array}{c} x_A \\ \vdash A, t_K \end{array} \right\rangle_{\sigma_B} \\ M4 \quad KDC \rightarrow A : & \quad \left\langle B \mid \vdash \begin{array}{c} x_B \\ \vdash B, t_K \end{array} \right\rangle_{\sigma_A} \end{aligned}$$

DIMOSTRAZIONE (SKETCH)

Alla ricezione del messaggio M1, per le ipotesi 2 e 3, $KDC \models A \mid \vdash \begin{array}{c} x_A \\ \vdash A \end{array}$. Alla ricezione del messaggio 3, per le ipotesi 2, 3, 4, 5, $B \mid \vdash \begin{array}{c} x_A \\ \vdash A \end{array}$. Un ragionamento analogo può essere fatto per i messaggi M2 e M4. Si ottiene quindi $B \mid \vdash \begin{array}{c} x_A \\ \vdash A \end{array}, A \mid \vdash \begin{array}{c} x_B \\ \vdash B \end{array}$

ESERCIZIO 3

Vedi appunti.

Nome e Cognome _____ Matricola _____

ESERCIZIO 1

punti: 10

Il candidato presenti le proprietà di una funzione hash sicura (MDC) illustrandone la relazione con la firma digitale.

ESERCIZIO 2

punti: 10

Si progetti un protocollo di distribuzione delle chiavi che permette ad Alice e Bob di stabilire una chiave di sessione K_{ab} attraverso Trent, un Key Distribution Center fidato. Alice e Bob non condividono *a-priori* alcun segreto a lungo termine. Al contrario, entrambi conoscono Π_T la chiave pubblica di Trent. Inoltre ciascuno di essi condivide con Trent un segreto che però non può essere utilizzato come chiave crittografica. Sia, ad esempio, π_A il segreto che Alice condivide con Trent. Si assuma che i clock siano sincronizzati.

Al termine di un'esecuzione, il protocollo deve garantire che i) Alice (Bob) conosca la chiave di sessione; ii) Alice (Bob) sappia che Bob (Alice) conosce la chiave di sessione; iii) attacchi di reply non siano possibili.

Il candidato è libero di scegliere lo schema di comunicazione.

ESERCIZIO 3

punti: 10

Il candidato descriva il protocollo base di Kerberos discutendo il dimensionamento delle finestre temporali caratteristiche del protocollo.

Soluzione

ESERCIZIO 1

Vedi appunti.

ESERCIZIO 2

Ipotesi

1. $\forall P \in \{A, B\}, P \models \overset{\Pi_T}{\mapsto} T$
2. $\forall P \in \{A, B\}, P \models \overset{\pi_p}{\rightleftharpoons} T, T \models \overset{\pi_p}{\rightleftharpoons} P$
3. $\forall P \in \{A, B\}, P \models \overset{K_p}{P \leftrightarrow T}$
4. $\forall P \in \{A, B\}, T \models \left(\overset{K_{ab}}{A \leftrightarrow B} \right)$
5. $\forall P \in \{A, B\}, P \models T \Rightarrow \left(\overset{K_{ab}}{A \leftrightarrow B} \right)$
6. $\forall P \in \{A, B\}, T \models \overset{K_p}{P} \Rightarrow \left(P \leftrightarrow T \right)$
7. $\forall P, Q \in \{A, B, T\}, P \models \#(t_q)$

Protocollo idealizzato

- M 1 $A \rightarrow B : \left\{ \left\langle A, B, \tau_a, \overset{K_a}{A \leftrightarrow T} \right\rangle_{\pi_a} \right\}_{\Pi_T}$
- M 2 $B \rightarrow T : \left\{ \left\langle A, B, \tau_a, \overset{K_a}{A \leftrightarrow T} \right\rangle_{\pi_a} \right\}_{\Pi_T}, \left\{ \left\langle B, A, \tau_b, \overset{K_b}{B \leftrightarrow T} \right\rangle_{\pi_b} \right\}_{\Pi_T}$
- M 3 $T \rightarrow B : \left\{ B, A, \tau_b + 1, \overset{K_{ab}}{A \leftrightarrow B} \right\}_{K_b}, \left\{ A, B, \tau_a + 1, \overset{K_{ab}}{A \leftrightarrow B} \right\}_{K_a}$
- M 4 $B \rightarrow A : \left\{ A, B, \tau_a + 1, \overset{K_{ab}}{A \leftrightarrow B} \right\}_{K_a}, \left\{ A, B, \tau'_b, \overset{K_{ab}}{A \leftrightarrow B} \right\}_{K_{ab}}$
- M 5 $A \rightarrow B : \left\{ B, A, \tau'_b + 1, \overset{K_{ab}}{A \leftrightarrow B} \right\}_{K_{ab}}$

Protocollo reale

- M 1 $A \rightarrow B : A, B, \{A, B, \tau_a, K_a, \pi_a\}_{\Pi_T}$
- M 2 $B \rightarrow T : \{A, B, \tau_a, K_a, \pi_a\}_{\Pi_T}, \{B, A, \tau_b, K_b, \pi_b\}_{\Pi_T}$
- M 3 $T \rightarrow B : \{B, A, \tau_b, K_{ab}\}_{K_b}, \{A, B, \tau_a, K_{ab}\}_{K_a}$
- M 4 $B \rightarrow A : \{A, B, \tau_a, K_{ab}\}_{K_a}, \{A, B, \tau'_b\}_{K_{ab}}$
- M 5 $A \rightarrow B : \{B, A, \tau'_b\}_{K_{ab}}$

ESERCIZIO 3

Vedi appunti.

Nome e Cognome _____ Matricola _____

ESERCIZIO 1

Punti:10

Con proprietà di linguaggio e precisione matematica, il candidato definisca un cifrario perfetto secondo la teoria di Shannon. Inoltre, il candidato dimostri che a) in un cifrario perfetto il numero di chiavi non può essere inferiore al numero dei messaggi; e che b) un cifrario asimmetrico può essere sicuro solo da un punto di vista computazionale.

ESERCIZIO 2

punti: 10

Alice e Bob utilizzano il protocollo di Diffie-Hellman per stabilire una chiave di sessione. Al fine di evitare l'attacco dell'uomo-nel-mezzo, Alice e Bob mantengono una relazione di fiducia con una terza entità fidata Trent, relazioni che si concretizzano nelle chiavi condivise *a priori* K_a e K_b , rispettivamente. Assumendo che gli orologi di Alice, Bob e Trent non siano sincronizzati, progettare un protocollo di distribuzione di una chiave di sessione K_{ab} che soddisfi i consueti requisiti di key authentication, key confirmation e non-replay.

ESERCIZIO 3

punti:10

Con proprietà di linguaggio e precisione matematica, il candidato descriva il protocollo di autenticazione di WEP e la sua vulnerabilità.

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

18 February 2014

NAME _____ SERIAL NO. _____

♥: MCE, SSI, SnR; ♠: DSS

EXERCISE NO. 1 (♥, ♠)

#MARKS: 10

With reference to hash functions,

1. Provide the definition of the *pre-image resistance*, *second-preimage resistance* and *collision resistance* properties;
2. Argue about the relevance of these properties w.r.t. to a digital signature scheme;
3. Argue about the security of hash functions with respect to black box attacks.

EXERCISE NO. 2 (♥, ♠)

#MARKS: 12

Let us consider the following *secret sharing scheme* that allows us to share a secret x between two non-colluding people so that each person alone is not able to reconstruct the secret.

1. Let x be a secret bit-string t -bit long;
2. Generate a t -bit truly random key k ;
3. Compute a *share* s , s.t., $s_i = x_i \oplus k_i$, $0 \leq i \leq t-1$;
4. Give the key k to Alice and the share s to Bob.

The candidate answers the following questions.

- Question A. Under the assumption that Alice and Bob do not collude, is the scheme perfectly secure? In other words, can Alice or Bob alone derive any information about the secret x ?
- Question B. What about if Alice and Bob collude?
- Question C. Generalize the scheme in order to share a secret among n users.
- How many key bits do we need to share a t -bit secret among n users?

EXERCISE NO. 3 (♥)

#marks: 8

How the problem of delegation is solved in Kerberos?
Describe the protocols for proxyable and forwardable tickets.

EXERCISE NO.4 (♠)

#MARKS: 8

Let (S, D) be a secure digital signature scheme with appendix. Let S and D be the signature and verification algorithm, respectively. Furthermore, let K_P be principal P 's public key, and CA a Certification Authority that is trusted by all principals of the system. Finally let H be a secure hash function. Which of the following *certificates* are useful to establish a secure channel with Alice? Argue why.¹

- (A) "Alice" $\parallel K_A \parallel S_{CA}(\text{Alice})$
- (B) "Alice" $\parallel K_A \parallel S_{CA}(K_A)$
- (C) "Alice" $\parallel K_A \parallel S_A(H(\text{"Alice"} \parallel K_A))$
- (D) "Alice" $\parallel K_A \parallel S_{CA}(\text{"Alice"} \parallel H(K_A))$
- (E) "Alice" $\parallel K_A \parallel S_{CA}(H(\text{"Alice"} \parallel K_A))$
- (F) "Alice" $\parallel K_A \parallel S_{Bob}(\text{"Alice"} \parallel K_A) \parallel \text{"Bob"} \parallel K_B \parallel S_{CA}(\text{"Bob"} \parallel K_B)$
- (G) "Alice" $\parallel K_A \parallel S_{Bob}(\text{"Alice"} \parallel K_A) \parallel \text{"Bob, CA: yes"} \parallel K_B \parallel S_{CA}(\text{"Bob, CA: yes"} \parallel K_B)$.

¹ Neglect any issue related to time.

SECURITY IN NETWORKED COMPUTING SYSTEMS
Master in Computer Engineering

18 September 2014

NAME _____ SERIAL NO. _____

SOLUTION

Exercise n.1

See theory

Exercise n.2

Question A. Under the assumption that users do not collude, the scheme is perfectly secure because the key is perfectly random and the share is the result of one-time pad.

Question B. If Alice and Bob collude, they can compute the secret.

Question C. Define $(n - 1)$ keys, $k_0, k_1, \dots, k_{n-1}$, and compute a share $s = x \oplus k_0 \oplus k_1 \oplus \dots \oplus k_{n-1}$. Then distribute share and keys to n different, non-colluding users. Notice that we need the presence (or collusion) of n users in order to reconstruct the secret.

A possible different approach is to 1) generate a single key k ; 2) compute a share $s = x \oplus k$, and finally 3) split k into $(n - 1)$ pieces, $P = \{p_1, p_2, \dots, p_{n-1}\}$. Each piece requires $v = t / (n - 1)$ bits. This solution is less secure than the previous one because $(n - 2)$ users may be sufficient to reconstruct the secret. Let us suppose that $(n - 2)$ users are present (or colluding) and that one user, say user u_i is missing. Then, reconstructing the secret through a brute force attack is a matter of attempting all possible sequences of v bits in order to guess the missing key piece. Its complexity is $O(2^v) = O\left(2^{\frac{t}{n-1}}\right) = O\left(2^{\frac{t}{n-1}}\right)$. This computation complexity could be affordable for an adversary also for a small value of n .

Question D. The number of key bits is $(n - 1) \times t$.

Exercise n. 3

See theory

Exercise n.4

- A. Certificate A does not link KA to Alice
- B. Certificate A does not link KA to Alice
- C. Certificate B is self-signed and Alice is not a trusted authority
- D. Certificate C is fine.
- E. Certificate C is fine.
- F. Bob, who is not a trusted authority, signed certificate D.
- G. Certificate E is fine: CA delegates B to sign certificates.

SICUREZZA NELLE RETI
Laurea Specialistica in Ingegneria Informatica

SICUREZZA DEI SISTEMI SOFTWARE (6/9 CFU)
Laurea Magistrale in Ingegneria Informatica

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

18 September 2014

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

10 June 2014

NAME _____ SERIAL NO. _____

EXERCISE NO. 1

#MARKS: 12

1. Prove that in a perfect cipher the number of keys cannot be smaller than the number of messages.
2. Consider the mono-alphabetic substitution cipher.¹
 - 2.1. Prove that it is not a perfect cipher.²
 - 2.2. Determine at least one cipher-text that would never decipher into plain-text "CS".

EXERCISE NO. 2

#MARKS: 10

Alice and Bob wish to establish a session key K_{AB} . To this purpose they run a key establishment protocol that exploits the presence of Trent, a trusted third party that plays the key server role. Alice and Bob share a long-term secret key with Trent. Let K_A and K_B these keys, respectively. Design the key establishment protocol that has to fulfil the following requirements:

- A. Clocks are not synchronized;
- B. The protocol is not subject to replay;
- C. At the end of the protocol, each principal has the proof that the peer holds the key;
- D. Alice cannot talk to Trent directly but indirectly through Bob

EXERCISE NO. 3

#marks: 8

1. What are certificates for?
 - A. Establishing an indissoluble link between an identifier and a public key.
 - B. Establishing the privileges of the owner of the certificate.
 - C. Establishing the trustworthiness of the certificate owner.
2. Describe the minimum set of data fields that you expect to find in a certificate.

¹ In a mono-alphabetic substitution cipher, a letter is mapped into a substitution letter. Substitution letters are defined by a random permutation of the alphabet.

² Suggestion: consider a 26-letter alphabet and determine the size of the plaintext for which the number of messages is larger than the number of keys.

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

29 January 2014

SOLUTION

EXERCISE #1

Question 1. See theory.

Question 2.1. Let M the plaintext space be composed of all messages that are N -letters long. These messages are 26^N . The mono-alphabetic substitution cipher is certainly not perfect when $26^N > 26!$ This occurs for $N \geq 6$.

Question 2.2. Any 2-letter message composed of two equal letters: "AA", "BB", ..., "ZZ".

EXERCISE #2.

$M1 \quad A \rightarrow B: A, B, n_A$

$M2 \quad B \rightarrow T: A, B, n_A, n_B$

$M3 \quad T \rightarrow B: \{A, B, n_A, K_{AB}\}_{K_A}, \{A, B, n_B, K_{AB}\}_{K_B}$

$M4 \quad B \rightarrow A: \{A, B, n_A, K_{AB}\}_{K_A}, \{A, B, n_A, n_B\}_{K_{AB}}$

$M5 \quad A \rightarrow B: \{A, B, n_B, n_A\}_{K_{AB}}$

EXERCISE #3.

Question 1. A.

Question 2. Subject identifier, subject public key, validity period and digital signature of the Certification Authority on the previous fields.

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

01 July 2014

NAME _____ SERIAL NO. _____

EXERCISE NO. 1

#MARKS: 10

With reference to the RSA algorithms

1. Describe its key-generation algorithm giving hints about its computing complexity;
2. Argue about its security.

EXERCISE NO. 2

#MARKS: 12

Alice and Bob use a shared password P to exchange a session key K through the following protocol

M1 $A \rightarrow B: E_P(K)$

Then key K is used to encrypt the session, $E_K(session)$.

Question 1. Is this scheme subject to offline password attack? Explain why.

Consider now the following protocol

M1 $A \rightarrow B: E_P(e_A)$

M2 $B \rightarrow A: E_P(E_{e_A}(K))$

Once again, key K is used to encrypt the session, $E_K(session)$.

Question 2. Is this scheme subject to an offline password attack? Explain why.

Question 3. Complete the scheme to be replay-resistant.

EXERCISE NO. 3

#marks: 8

Define a secure hash function and explain why its properties are relevant for digital signatures.

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

01 July 2014

SOLUTION

EXERCISE #1

See theory

EXERCISE #2

Question 1. The adversary may mount a password attack as follows

Repeat

$P' \leftarrow \text{guessPassword}();$

$K' \leftarrow D_{P'}(E_P(K));$

Until K' correctly decrypts $E_K(\text{session})$

This attack is particularly effective when the secret P is a password chosen by a naïve user.

Question 2.

In order to mount a password attack, an adversary knows messages $M1$, $M2$ and the encrypted session. Let us suppose the adversary makes a guess P' . Then from message $M1$, the adversary derives e_A' . The adversary's problem now consists in checking whether its guess is correct. He can exploit message $M2$ and the encrypted session. In other words, the adversary has to check whether there exists a number K' such that 1) $E_{e_A'}(K') = E_{e_A}(K)$; and, 2) K' decrypts the encrypted session. In other words, a password guess cannot be discarded without doing a brute-force attack on K . Since e_A and R are generated over a (presumably) large key space, such an attack is (hopefully) very expensive even though the password space is small.

In a more quantitative way, the number of trials is $|\mathcal{P}| \times |\mathcal{K}|$ where $\mathcal{P}$ and $\mathcal{K}$ are the password space and the key space whereas $|\cdot|$ denotes set cardinality operator.

Question 3.

M1 $A \rightarrow B: E_P(e_A)$

M2 $B \rightarrow A: E_P(E_{e_A}(K))$

M3 $A \rightarrow B: E_R(\text{nonce}_A)$

M4 $B \rightarrow A: E_R(\text{nonce}_A, \text{nonce}_B)$

M5 $A \rightarrow B: E_R(\text{nonce}_B)$

EXERCISE #3.

See theory.

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

22 July 2014

NAME _____ SERIAL NO. _____

♥: MCE, SSI, SnR; ♠: DSS

EXERCISE NO. 1 (♥, ♠)

#MARKS: 10

With reference to the CBC encryption mode,

1. Illustrate the scheme and present the related equations;
2. Discuss the advantages with respect to ECB;
3. Discuss the disadvantages with respect to ECB;
4. Argue whether it can be used with an asymmetric cipher.

EXERCISE NO. 2 (♥)

#MARKS: 10

Consider the following key establishment protocol

- $M1 \quad A \rightarrow B: \quad A, r_A$
 $M2 \quad B \rightarrow T: \quad A, B, r_A$
 $M3 \quad T \rightarrow B: \quad \{A, B, r_A, k\}_{k_A}, \{A, B, r_T, k\}_{k_B}$
 $M4 \quad B \rightarrow A: \quad \{A, B, r_A, k\}_{k_A}, \{A, B\}_k$
 $M5 \quad A \rightarrow B: \quad \{B, A\}_k$

where k is the session key, k_X is the key that principal X secretly shares with the trusted third party T , and finally, r_X is the nonce generated by principal X .

The candidate has to

1. Analyse the protocol by means of the BAN logic;
2. Argue whether the protocol is subject to a replay attack;
3. Argue the consequences deriving from a session key being compromised;
4. Suggest improvements to the protocol.

EXERCISE NO. 3 (♥)

#marks: 10

With reference to Kerberos,

1. Describe the basic protocol;
2. Explain why it requires the assumption that clock are synchronized;
3. Illustrate the reasons leading to the introduction of the Ticket Granting Service.

EXERCISE NO.4 (♠)

#MARKS: 10

The candidate

1. Present the Merkle-Damgard scheme for collision resistant hash function $H()$;
2. State the property of the compression function $h()$ for $H()$ to be a CRHF;
3. Present the Davies-Meyer scheme for $h()$

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

01 July 2014

SOLUTION

EXERCISE #1

See theory

EXERCISE #2

Question 1. In the analysis, the crucial point to notice is that M3 does not carry any proof of freshness for B . It follows that B cannot believe $A \xleftarrow{k} B$ unless we assume that either B believes $\text{fresh}(r_T)$ or B believes $\text{fresh}(k)$.

Question 2. In both cases, the assumption opens the door to a replay attack. Let us suppose that an adversary M has recorded all the messages of a previous execution of the protocol, namely execution i . Then, the adversary M may play a man-in-the-middle attack and replay all the messages of execution i to B so leading B to reuse key k and believe that the peer is A .

Question 3. As a replay is possible, if M is able to obtain a session key k , then it can impersonate A and reuse k repeatedly at his will.

Question 4. In order to avoid the problems highlighted at points 2 and 3, the protocol can be amended by introducing a nonce r_B generated by B in message M2 and M3. The protocol becomes as follows

M1 $A \rightarrow B: A, r_A$
M2 $B \rightarrow T: A, B, r_A, r_B$
M3 $T \rightarrow B: \{A, B, r_A, k\}_{k_A}, \{A, B, r_B, k\}_{k_B}$
M4 $B \rightarrow A: \{A, B, r_A, k\}_{k_A}, \{A, B\}_k$
M5 $A \rightarrow B: \{B, A\}_k$

EXERCISE #3.

See theory.

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

18 September 2014

NAME _____ SERIAL NO. _____

♥: MCE, SSI, SnR; ♠: DSS

EXERCISE NO. 1 (♥, ♠)

#MARKS: 10

With reference to hash functions,

1. Provide the definition of the *pre-image resistance*, *second-preimage resistance* and *collision resistance* properties;
2. Argue about the relevance of these properties w.r.t. to a digital signature scheme;
3. Argue about the security of hash functions with respect to black box attacks.

EXERCISE NO. 2 (♥, ♠)

#MARKS: 12

Let us consider the following *secret sharing scheme* that allows us to share a secret x between two non-colluding people so that each person alone is not able to reconstruct the secret.

1. Let x be a secret bit-string t -bit long;
2. Generate a t -bit truly random key k ;
3. Compute a *share* s , s.t., $s_i = x_i \oplus k_i$, $0 \leq i \leq t-1$;
4. Give the key k to Alice and the share s to Bob.

The candidate answers the following questions.

- Question A. Under the assumption that Alice and Bob do not collude, is the scheme perfectly secure? In other words, can Alice or Bob alone derive any information about the secret x ?
- Question B. What about if Alice and Bob collude?
- Question C. Generalize the scheme in order to share a secret among n users.
- How many key bits do we need to share a t -bit secret among n users?

EXERCISE NO. 3 (♥)

#marks: 8

How the problem of delegation is solved in Kerberos?
Describe the protocols for proxiable and forwardable tickets.

EXERCISE NO.4 (♠)

#MARKS: 8

Let (S, D) be a secure digital signature scheme with appendix. Let S and D be the signature and verification algorithm, respectively. Furthermore, let K_P be principal P 's public key, and CA a Certification Authority that is trusted by all principals of the system. Finally let H be a secure hash function. Which of the following *certificates* are useful to establish a secure channel with Alice? Argue why.¹

- (A) "Alice" $\parallel K_A \parallel S_{CA}(\text{Alice})$
- (B) "Alice" $\parallel K_A \parallel S_{CA}(K_A)$
- (C) "Alice" $\parallel K_A \parallel S_A(H(\text{"Alice"} \parallel K_A))$
- (D) "Alice" $\parallel K_A \parallel S_{CA}(\text{"Alice"} \parallel H(K_A))$
- (E) "Alice" $\parallel K_A \parallel S_{CA}(H(\text{"Alice"} \parallel K_A))$
- (F) "Alice" $\parallel K_A \parallel S_{Bob}(\text{"Alice"} \parallel K_A) \parallel \text{"Bob"} \parallel K_B \parallel S_{CA}(\text{"Bob"} \parallel K_B)$
- (G) "Alice" $\parallel K_A \parallel S_{Bob}(\text{"Alice"} \parallel K_A) \parallel \text{"Bob, CA: yes"} \parallel K_B \parallel S_{CA}(\text{"Bob, CA: yes"} \parallel K_B)$.

¹ Neglect any issue related to time.

SECURITY IN NETWORKED COMPUTING SYSTEMS
Master in Computer Engineering

18 September 2014

NAME _____ SERIAL NO. _____

SOLUTION

Exercise n.1

See theory

Exercise n.2

Question A. Under the assumption that users do not collude, the scheme is perfectly secure because the key is perfectly random and the share is the result of one-time pad.

Question B. If Alice and Bob collude, they can compute the secret.

Question C. Define $(n - 1)$ keys, $k_1, k_2, \dots, k_{n-1}$, and compute a share $s = x \oplus k_1 \oplus k_2 \oplus \dots \oplus k_{n-1}$. Then distribute share and keys to n different, non-colluding users. Notice that we need the presence (or collusion) of n users in order to reconstruct the secret.

A possible different approach is to 1) generate a single key k ; 2) compute a share $s = x \oplus k$, and finally 3) split k into $(n - 1)$ pieces, $P = \{p_1, p_2, \dots, p_{n-1}\}$. Each piece requires $v = t / (n - 1)$ bits. This solution is less secure than the previous one because $(n - 2)$ users may be sufficient to reconstruct the secret. Let us suppose that $(n - 2)$ users are present (or colluding) and that one user, say user u_i is missing. Then, reconstructing the secret through a brute force attack is a matter of attempting all possible sequences of v bits in order to guess the missing key piece. Its complexity is $O(2^v) = O(2^{t/(n-1)}) = O(2^{n-1 \sqrt{t}})$. This computation complexity could be affordable for an adversary also for a small value of n .

Question D. The number of key bits is $(n - 1) \times t$.

Exercise n. 3

See theory

Exercise n.4

- A. Certificate A does not link KA to Alice
- B. Certificate A does not link KA to Alice
- C. Certificate B is self-signed and Alice is not a trusted authority
- D. Certificate C is fine.
- E. Certificate C is fine.
- F. Bob, who is not a trusted authority, signed certificate D.
- G. Certificate E is fine: CA delegates B to sign certificates.

SICUREZZA NELLE RETI
Laurea Specialistica in Ingegneria Informatica

SICUREZZA DEI SISTEMI SOFTWARE (6/9 CFU)
Laurea Magistrale in Ingegneria Informatica

SECURITY IN NETWORKED COMPUTING SYSTEMS
Computer Engineering

18 September 2014

SECURITY IN NETWORKED COMPUTING SYSTEMS

Computer Engineering

15 June 2015

EXERCISE NO. 1

#MARKS: 10

With reference to the Diffie-Hellmann key establishment scheme,

1. Describe the scheme;
2. Argue its security with respect to a passive adversary;
3. Argue its security with respect to an active adversary.

EXERCISE NO. 2

#MARKS: 10

Let us consider an implementation of One-Time Pad (OTP) on n bit that makes it a perfect cipher.

1. Let $k_0 = \overbrace{000\dots000}^n$ be a key and m an n -bit message. Compute the cipher-text $c = m \oplus k_0$.
2. Is there any advantage, or disadvantage, in removing key k_0 from the set of possible keys?
3. Let us suppose that $c = \text{"The password of my bank account is my wife's birthday"}$. Which are the most probable plaintext messages (determine at least two)? Which are the corresponding keys?

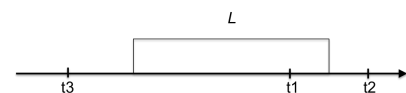
EXERCISE NO. 3

#marks: 10

Let us consider the “simplified” certificate $Cert_A = A, pubK_A, L, \sigma$, with $\sigma = S_{CA}(t)$ and $t = H(A, ||pubK_A||L)$, where A is the user identifier, $pubK_A$ is the user’s public key, L is the validity period, H is a collision-resistant hash function and S is a secure digital signature scheme.

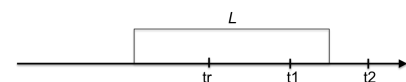
With reference to the figure on the right, give a motivated answer to the following questions:

1. Is $Cert_A$ valid at time $t = t1$?
2. Is $Cert_A$ valid at time $t = t2$?
3. Is $Cert_A$ valid at time $t = t3$?



With reference to the figure on the right, assume that $Cert_A$ has been revoked at time $t = tr$, give a motivated answer to the following questions:

4. Is $Cert_A$ certainly present in CRL at time $t = t1$?
5. Is $Cert_A$ certainly present in CRL at time $t = t2$?



SECURITY IN NETWORKED COMPUTING SYSTEMS

Computer Engineering

15 June 2015

SOLUTION

Exercise n.1

See theory.

Exercise n.2

Question 1.

$$c = m$$

Question 2.

If you remove k_0 , then the number of keys become $2^n - 1$. It follows that the number of keys becomes smaller than the number of messages and therefore the resulting cipher is not perfect anymore.

Question 3.

Four possible messages are:

The password of my bank account is my wife's birthday
The password of my bank account is my aunt's birthday
The password of my bank account is b4nk-P4ssw0rd12345
Love of my life you left me. You have broken my heart

The respective keys are obtained by computing $k_i = c \oplus m_i$.

Exercise n. 3

1: valid

2, 3: invalid as outside the validity interval

4: the certificate is certainly in CRL

5: the certificate may not be in CRL because, it is not valid anymore, it might have been removed to shorten the CRL itself.

SICUREZZA NELLE RETI SICUREZZA DEI SISTEMI SOFTWARE (6/9 CFU)

Laurea Specialistica in Ingegneria Informatica

Laurea Magistrale in Ingegneria Informatica

SECURITY IN NETWORKED COMPUTING SYSTEMS

Computer Engineering

15 june 2015

SECURITY IN NETWORKED COMPUTING SYSTEMS

Computer Engineering

15 July 2015

EXERCISE NO. 1

#MARKS: 10

In RSA, encryption/decryption performance depends on the key's binary representation.

1. Argue the above sentence.
2. Argue why the public exponent $e = 3$ or $e = 2^{16} + 1$ are a good choice.
3. Argue whether a private exponent d with only two 1's in its binary representation is a good choice or not.
4. Is a public exponent with only one 1 in its binary representation a viable solution?

EXERCISE NO. 2

#MARKS: 12

Alice and Bob share a password (or PIN) P . For identification, they run the following challenge-response protocol:

M1 A → B: CHL

M2 B → A: RSP

Indicate which one of the following implementations of CHL and RSP is secure w.r.t. to an off-line password-guessing attack.

1. CHL = r_a and RSP = $\{r_a\}_K$;
2. CHL = r_a and RSP = $H_K(r_a)$;
3. CHL = r_a and RSP = $\{r_a, r_b\}_K$;
4. CHL = r_a and RSP = $H_K(r_a || r_b)$;
5. CHL = r_a and RSP = $\{H_K(r_a)\}_{\Pi_A}$;
6. CHL = r_a and RSP = $\{H_K(r_a), r_b\}_{\Pi_A}$.

where: **i)** $\{\cdot\}_\kappa$ denotes encryption by means of key κ (whether symmetric or asymmetric depends on the context), **ii)** $H_k(\cdot)$ denotes a secure MAC; **iii)** r_x is a random number generated by X ; **iv)** K is a symmetric key, with $K = f(P)$ and $f(\cdot)$ a deterministic function; and, finally, **v)** Π_A is A's public key, known to B.

EXERCISE NO. 3

#marks: 8

Indicate which of the following certificates is correct.

1. $A, \Pi_A, L, S_{CA}(H(A || \Pi_A || L))$
2. $A, \Pi_A, L, S_{CA}(H(\Pi_A || L))$
3. $A, \Pi_A, L, S_{CA}(H(A || \Pi_A))$
4. $A, \Pi_A, L, S_{CA}(A || \Pi_A || L)$

SECURITY IN NETWORKED COMPUTING SYSTEMS

Computer Engineering

15 July 2015

SOLUTION

Exercise n.1

For the relationship between performance and key-bit configuration see theory. From that relationship, it follows that the number of multiplications depends on the number of bits equal to 1.

We choose those values for e because they contain only two 1's in their binary representation.

Selecting d so that it has only two 1's in its binary representation would reduce the private key space and make it vulnerable to exhaustive key search.

If e contains only one 1 in its binary representation, then its value is either 1 or even. In both case, it does not fulfill the constraint specified by the RSA key generation algorithm.

Exercise n.2

Case 1 is insecure. The adversary guesses a password, computes a key and decrypts RSP. Then (s)he compares the resulting plaintext with r_a . It follows the complexity of the attack is equal to the password-guessing attack.

Case 2 is insecure. The adversary guesses a password and computes a key. Then (s)he computes the MAC of r_a and checks whether it is equal to RSP. It follows the complexity of the attack is equal to the password-guessing attack.

Case 3 is insecure. The adversary guesses a password, computes a key and decrypts RSP. Then (s)he compares the resulting plaintext with the first field of the resulting plaintext. It follows the complexity of the attack is equal to the password-guessing attack.

Case 4 is insecure. A is not able to verify RSP because (s)he does not know r_b .

Case 5 is insecure. The adversary guesses a password and computes a key. Then (s)he computes the MAC of r_a , encrypts it by means of Π_A , and checks whether it is equal to RSP. It follows the complexity of the attack is equal to the password-guessing attack.

Case 6 is secure, because r_b randomizes RSP.

Exercise n. 3

Case 1 and 4 are secure.

Case 2 is insecure because it doesn't link the user identifier to his/her key.

Case 3 is insecure because it doesn't link the period of validity to the user's key and user's identifier

SECURITY IN NETWORKED COMPUTING SYSTEMS

Computer Engineering

22 July 2015

EXERCISE NO. 1

#MARKS: 10

With reference to a perfect cipher,

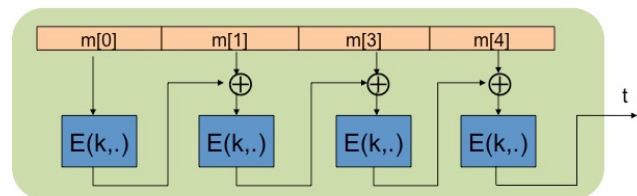
1. State the Shannon's formal definition of perfect cipher and give an intuitive explanation of the definition;
2. Prove that in a perfect cipher the number of keys cannot be smaller than the number of messages;
3. Argue whether an asymmetric cipher can be perfect or not.

EXERCISE NO. 2

#MARKS: 10

State the security definition of a Message Authentication Code (MAC).

List and briefly introduce the main methods of building a MAC out of other cryptographic primitives.



raw CBC

Show that the rawCBC-MAC (see figure) is insecure. Hint: compute the MAC t_1 of the single block message m_1 and the MAC t_2 of the two-block message $m_2 = (m_1, m_1 \oplus t_1)$. Generalize the attack for an arbitrary number of blocks message.

EXERCISE NO. 3

#marks: 10

Let us assume that a plaintext P has the format specified in the figure where s is an 8-bit field that specifies an amount of money and p is a *parity bit* s.t.



p is 0 if the number of 1s in the plaintext (bit p excluded) is even; it is 1 otherwise. The whole plaintext is encrypted by means of one-time-pad.

Q1. Does this encryption scheme suffer from malleability? Motivate the answer.

Q2. Assume that field s specifies the value 130. Argue whether and how, it is possible to modify the cipher-text so that the decrypted plaintext specifies 146 in the field s and such a modification goes undetected.

Q3. Propose a possible countermeasure.

SECURITY IN NETWORKED COMPUTING SYSTEMS

Computer Engineering

22 July 2015

SOLUTION

Exercise n.1

Q1, Q2, Q3. See theory.

Exercise n.2

Q1. See theory

Q2. See theory.

Q3. Compute t_1 and t_2 as hinted, and verify that $t_1 = t_2$. This means that a collision has arisen. One possible way to generalize is to consider a message having the following structure $m = (m_1, m_1 \oplus t_1, \dots, m_1 \oplus t_1)$, where m_1 is a single block message and t_1 is m_1 's tag.

Exercise n. 3

Q1. The encryption scheme is malleable. A simple way to prove it is the following. Let $P[i]$, $C[i]$, and $K[i]$ be the i -th bit of the plaintext, ciphertext and key, respectively, s.t. $C[i] = P[i] \text{ xor } K[i]$. Notice that $P[0] = p$. Finally let C' be the modified ciphertext and P' the resulting plaintext after decryption. Notice that an adversary can easily complement a bit of the plaintext by operating on the ciphertext. Assume that the adversary wishes to complement bit i . Then, (s)he computes $C'[i] = C[i] \text{ xor } 1 = (P[i] \text{ xor } K[i]) \text{ xor } 1 = (P[i] \text{ xor } 1) \text{ xor } K[i] = P'[i] \text{ xor } K[i]$. It follows that $P'[i] = P[i] \text{ xor } 1$, that is, $P'[i]$ is the complement of $P[i]$ ($P'[i] = \sim P[i]$).

In order for the attack to go undetected, and the scheme to be malleable, the parity bit must be consistently modified as well. Notice that since $P[i]$ is complemented the number of 1 either increment or decrement by one. In both cases the parity bit has to be complemented as well. This implies that $C'[0] = C[0] \text{ xor } 1$.

Q2. The attack consists in complementing $C[0]$ and the 5-th most significant bit in s .

Q3. The problem can be solved by replacing the parity bit by a tag resulting from a secure hash function.

Nome e Cognome _____ Matricola _____

ESERCIZIO 1**PUNTI: 8**

(A.A. 2004-05). Il candidato spieghi con precisione matematica e proprietà di linguaggio il legame tra n , il numero di bit di un blocco, e k , il numero di bit di una chiave, in un *true random cipher*. Il candidato discuta inoltre le difficoltà pratiche legate alla realizzazione di tale tipo di cifrario.

(A.A. 2005-06). Il candidato dimostri che se un cifrario è perfetto allora il numero delle chiavi deve essere maggiore o uguale al numero dei messaggi.

ESERCIZIO 2**PUNTI: 14 (4, 5, 5)**

Si consideri il seguente protocollo di distribuzione delle chiavi orientato a stabilire una chiave di sessione $K_{AB} = h(k_a, k_b)$ tra i processi A e B , con h funzione hash one-way:

M1	$A \rightarrow B: E_{e_b}(k_a, A)$	E: cifrario asimmetrico; k_a e k_b: quantità segrete scelte rispettivamente da A e B; e_a ed e_b: le chiavi pubbliche, rispettivamente, di A e B
M2	$B \rightarrow A: E_{e_a}(k_a, k_b)$	
M3	$A \rightarrow B: E_{e_b}(k_b)$	

Si assuma che

- le quantità k_a e k_b non siano mai riutilizzate;
- ciascun processo conosca la chiave pubblica dell'altro, il candidato risponda alle seguenti domande motivando le risposte.

Quesito A. Il protocollo garantisce la confidenzialità della chiave di sessione?

Quesito B. Analizzando il protocollo con la logica BAN, il candidato discuta se il protocollo garantisce le proprietà di key authentication e di key confirmation specificando le ipotesi sotto le quali tali proprietà valgono.

Si assuma adesso che l'ipotesi (i) non sia più verificata.

Quesito C. Il candidato verificata, quali conseguenze possono scaturire.

ESERCIZIO 3**PUNTI: 8 (4, 4)**

Si consideri il protocollo (semplificato) di identificazione di WEP (IEEE 802.11) per mezzo del quale una mobile station MS si identifica presso un access point AP per avere accesso alla rete (sia k una chiave segreta su 104 bit, condivisa tra MS ed AP):

- MS invia una richiesta di identificazione ad AP.
- AP genera in modo casuale una challenge χ su 128 bit e la invia a MS.
- MS genera in modo casuale un vettore di inizializzazione v su 24 bit, calcola la response $\rho = E_{k,v}(\chi)$ ed invia ad AP la frame $\langle v, \rho \rangle$.
- Alla ricezione della frame, AP estrae le quantità v e ρ , e verifica se $\chi = D_{k,v}(\rho)$. Se la verifica ha esito positivo, AP permette ad MS l'accesso alla rete; altrimenti, vieta tale accesso.

Il cifrario utilizzato è definito in Figura 1, dove m_i e c_i sono, rispettivamente, l' i -esimo byte del testo in chiaro e del testo cifrato. La chiave k ed il vettore di inizializzazione v sono concatenati per formare il seme s del generatore random sicuro di byte detto *Key Sequence Generator* (KSG). Con z_i si denota l' i -esimo byte del *key stream* generato da KSG.

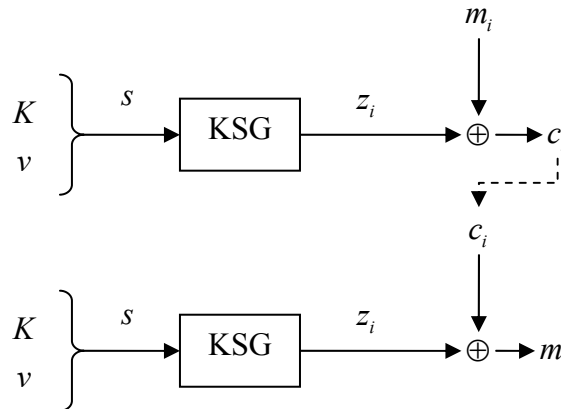


Figura 1. Il cifrario di WEP.

Si assuma che la chiave K è fissa ed unica per tutte le mobile station appartenenti alla rete.

Quesito A. Il candidato discuta se il protocollo WEP garantisce l'identificazione oppure no ovvero se un avversario (passivo) può impersonare una mobile station della rete.

Si assuma adesso di modificare il protocollo in modo tale che, al passo 2, AP generi in modo causale il vettore di inizializzazione v e lo invii in chiaro a MS insieme alla challenge¹.

Quesito B. Il candidato definisca un dictionary attack contro questa variante del protocollo di identificazione e valuti la dimensione in byte del dizionario.

¹ Si noti che adesso non è più necessario trasmettere v insieme alla response.

SOLUZIONE

ESERCIZIO 1

(A.A. 2004-05). Con n bit si hanno 2^n possibili blocchi in chiaro. Un true random cipher realizza tutte le possibili permutazioni, cioè $2^n!$ e richiede perciò $k = \log_2(2^n!)$ che risulta essere $O(n2^n)$.

(A.A. 2005-06). Per prima cosa si osserva che affinché il cifrario sia invertibile è necessario che il numero di testi cifrati N_c sia maggiore o uguale al numero di testi in chiaro N_m , $N_c \geq N_m$. La dimostrazione è per assurdo. Supponiamo che il numero di chiavi N_k sia minore del numero N_m di messaggi in chiaro, $N_k < N_m$. Ne segue quindi che $N_k < N_c$.

Sia m un messaggio che ha probabilità non nulla di essere trasmesso, $P(M = m) \neq 0$. Dalla condizione $N_k < N_c$ segue che esiste un crittogramma c che non è immagine di m . Perciò, $P(M = m, C = c) = 0 \neq P(M = m)$, contro l'ipotesi che il cifrario sia perfetto.

ESERCIZIO 2

Quesito A. Il protocollo garantisce la confidenzialità. Per determinare il valore di K_{AB} è necessario conoscere le quantità k_a e k_b . Tuttavia queste quantità viaggiano in rete in forma cifrata.

Quesito B. Il protocollo è una versione semplificata del protocollo Needham-Schroeder a chiave pubblica. Il protocollo garantisce sia la key authentication sia la key confirmation. Formalmente,

$$A \models B \models A \xrightarrow{k_b} B \text{ e } B \models A \models A \xrightarrow{k_a} B.$$

Quesito C. Se l'ipotesi (i) non è verificata, il protocollo non garantisce la proprietà di key authentication. Supponiamo che la quantità k_a sia riutilizzata da A e che un avversario M abbia registrato i messaggi M1 ed M2 relativi all'esecuzione del protocollo in cui k_a è stata utilizzata la prima volta. L'avversario M potrebbe eseguire il seguente attacco:

- l'avversario M induce A ad iniziare una nuova istanza del protocollo con B ;
- quando A invia il messaggio M1' relativo alla nuova esecuzione del protocollo, contenente la quantità riutilizzata k_a , l'avversario M determina che $M1=M1'$, e risponde con M2. Alla ricezione di questo messaggio il processo A crede di parlare effettivamente con B .

Si noti che questo attacco ha come effetto collaterale il riutilizzo della vecchia chiave di sessione K_{ab} (la quantità k_b è contenuta nel messaggio M2 replicato da M). L'avversario M potrebbe non conoscere tale chiave ma potrebbe comunque replicare vecchi messaggi relativi alla sessione K_{ab} che A considererebbe come provenienti da B . Il danno sarebbe massimo se M , per altre vie, fosse riuscito ad impadronirsi di K_{ab} .

Considerazioni simili possono essere fatte per B se questo processo riutilizza la quantità k_b .

ESERCIZIO 3

Quesito A. Il protocollo non garantisce l'identificazione. Supponiamo che un avversario A intercetti una coppia challenge-response. Più precisamente, A intercetta la challenge e la frame f che trasporta la relativa response. Tale frame oltre a response trasporta anche il vettore di inizializzazione v utilizzato per cifrare la challenge. Dalla challenge (testo in chiaro) e dalla response (crittogramma) è possibile ricavare il keystream $\{z_i(v)\}$ facendo l'or-esclusivo tra le due quantità. A questo punto l'avversario conosce una coppia (vettore di inizializzazione, keystream) $(v, \{z_i(v)\})$ che può riutilizzare in (un numero indefinito di) altre esecuzioni del protocollo di identificazione.

Quesito B. Come nel caso precedente l'avversario riesce a violare il protocollo riutilizzando una coppia $(v, \{z_i(v)\})$. Il keystream può essere ricavato come nel caso precedente mentre v può essere ricavato dalla frame che trasporta la challenge. Differentemente a prima, adesso è AP che seleziona v . L'avversario quindi deve costruirsi un dizionario $DIZ = \{(v, \{z_i(v)\}) \mid v \in V_{24}\}$, con V_{24} l'insieme di tutte le sequenze di 24 bit. DIZ ha 2^{24} voci, ciascuna di $sizeof(v) + sizeof(\{z_i(v)\})$ byte. La quantità v occupa 3 byte. Il keystream $\{z_i(v)\}$ ha per definizione la stessa dimensione della challenge, cioè $128/8 = 16$ byte. Ne segue quindi che una voce del dizionario occupa 19 byte. Ne segue perciò che il DIZ ha una dimensione pari a $19 \times 2^{24} \cong 20$ Mbyte.

Nome e Cognome _____ Matricola _____

ESERCIZIO 1**PUNTI: 8**

(A.A. 2004-05). Il candidato spieghi con precisione matematica e proprietà di linguaggio il legame tra n , il numero di bit di un blocco, e k , il numero di bit di una chiave, in un *true random cipher*. Il candidato discuta inoltre le difficoltà pratiche legate alla realizzazione di tale tipo di cifrario.

(A.A. 2005-06). Il candidato dimostri che se un cifrario è perfetto allora il numero delle chiavi deve essere maggiore o uguale al numero dei messaggi.

ESERCIZIO 2**PUNTI: 14 (4, 5, 5)**

Si consideri il seguente protocollo di distribuzione delle chiavi orientato a stabilire una chiave di sessione $K_{AB} = h(k_a, k_b)$ tra i processi A e B , con h funzione hash one-way:

M1	$A \rightarrow B: E_{e_b}(k_a, A)$	E: cifrario asimmetrico; k_a e k_b: quantità segrete scelte rispettivamente da A e B; e_a ed e_b: le chiavi pubbliche, rispettivamente, di A e B
M2	$B \rightarrow A: E_{e_a}(k_a, k_b)$	
M3	$A \rightarrow B: E_{e_b}(k_b)$	

Si assuma che

- le quantità k_a e k_b non siano mai riutilizzate;
- ciascun processo conosca la chiave pubblica dell'altro, il candidato risponda alle seguenti domande motivando le risposte.

Quesito A. Il protocollo garantisce la confidenzialità della chiave di sessione?

Quesito B. Analizzando il protocollo con la logica BAN, il candidato discuta se il protocollo garantisce le proprietà di key authentication e di key confirmation specificando le ipotesi sotto le quali tali proprietà valgono.

Si assuma adesso che l'ipotesi (i) non sia più verificata.

Quesito C. Il candidato verificata, quali conseguenze possono scaturire.

ESERCIZIO 3**PUNTI: 8 (4, 4)**

Si consideri il protocollo (semplificato) di identificazione di WEP (IEEE 802.11) per mezzo del quale una mobile station MS si identifica presso un access point AP per avere accesso alla rete (sia k una chiave segreta su 104 bit, condivisa tra MS ed AP):

- MS invia una richiesta di identificazione ad AP.
- AP genera in modo casuale una challenge χ su 128 bit e la invia a MS.
- MS genera in modo casuale un vettore di inizializzazione v su 24 bit, calcola la response $\rho = E_{k,v}(\chi)$ ed invia ad AP la frame $\langle v, \rho \rangle$.
- Alla ricezione della frame, AP estrae le quantità v e ρ , e verifica se $\chi = D_{k,v}(\rho)$. Se la verifica ha esito positivo, AP permette ad MS l'accesso alla rete; altrimenti, vieta tale accesso.

Il cifrario utilizzato è definito in Figura 1, dove m_i e c_i sono, rispettivamente, l' i -esimo byte del testo in chiaro e del testo cifrato. La chiave k ed il vettore di inizializzazione v sono concatenati per formare il seme s del generatore random sicuro di byte detto *Key Sequence Generator* (KSG). Con z_i si denota l' i -esimo byte del *key stream* generato da KSG.

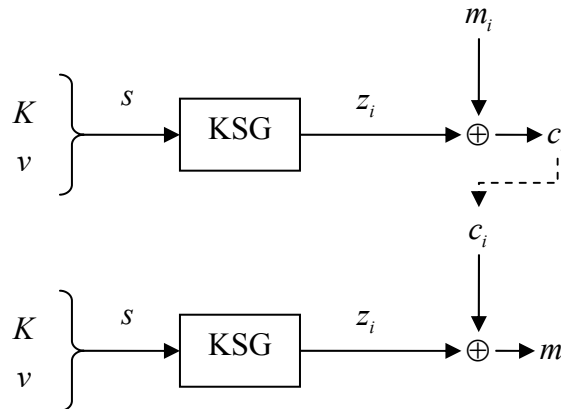


Figura 1. Il cifrario di WEP.

Si assuma che la chiave K è fissa ed unica per tutte le mobile station appartenenti alla rete.

Quesito A. Il candidato discuta se il protocollo WEP garantisce l'identificazione oppure no ovvero se un avversario (passivo) può impersonare una mobile station della rete.

Si assuma adesso di modificare il protocollo in modo tale che, al passo 2, AP generi in modo causale il vettore di inizializzazione v e lo invii in chiaro a MS insieme alla challenge¹.

Quesito B. Il candidato definisca un dictionary attack contro questa variante del protocollo di identificazione e valuti la dimensione in byte del dizionario.

¹ Si noti che adesso non è più necessario trasmettere v insieme alla response.

SOLUZIONE

ESERCIZIO 1

(A.A. 2004-05). Con n bit si hanno 2^n possibili blocchi in chiaro. Un true random cipher realizza tutte le possibili permutazioni, cioè $2^n!$ e richiede perciò $k = \log_2(2^n!)$ che risulta essere $O(n2^n)$.

(A.A. 2005-06). Per prima cosa si osserva che affinché il cifrario sia invertibile è necessario che il numero di testi cifrati N_c sia maggiore o uguale al numero di testi in chiaro N_m , $N_c \geq N_m$. La dimostrazione è per assurdo. Supponiamo che il numero di chiavi N_k sia minore del numero N_m di messaggi in chiaro, $N_k < N_m$. Ne segue quindi che $N_k < N_c$.

Sia m un messaggio che ha probabilità non nulla di essere trasmesso, $P(M = m) \neq 0$. Dalla condizione $N_k < N_c$ segue che esiste un crittogramma c che non è immagine di m . Perciò, $P(M = m, C = c) = 0 \neq P(M = m)$, contro l'ipotesi che il cifrario sia perfetto.

ESERCIZIO 2

Quesito A. Il protocollo garantisce la confidenzialità. Per determinare il valore di K_{AB} è necessario conoscere le quantità k_a e k_b . Tuttavia queste quantità viaggiano in rete in forma cifrata.

Quesito B. Il protocollo è una versione semplificata del protocollo Needham-Schroeder a chiave pubblica. Il protocollo garantisce sia la key authentication sia la key confirmation. Formalmente,

$$A \models B \models A \xrightarrow{k_b} B \text{ e } B \models A \models A \xrightarrow{k_a} B.$$

Quesito C. Se l'ipotesi (i) non è verificata, il protocollo non garantisce la proprietà di key authentication. Supponiamo che la quantità k_a sia riutilizzata da A e che un avversario M abbia registrato i messaggi M1 ed M2 relativi all'esecuzione del protocollo in cui k_a è stata utilizzata la prima volta. L'avversario M potrebbe eseguire il seguente attacco:

- l'avversario M induce A ad iniziare una nuova istanza del protocollo con B ;
- quando A invia il messaggio M1' relativo alla nuova esecuzione del protocollo, contenente la quantità riutilizzata k_a , l'avversario M determina che $M1=M1'$, e risponde con M2. Alla ricezione di questo messaggio il processo A crede di parlare effettivamente con B .

Si noti che questo attacco ha come effetto collaterale il riutilizzo della vecchia chiave di sessione K_{ab} (la quantità k_b è contenuta nel messaggio M2 replicato da M). L'avversario M potrebbe non conoscere tale chiave ma potrebbe comunque replicare vecchi messaggi relativi alla sessione K_{ab} che A considererebbe come provenienti da B . Il danno sarebbe massimo se M , per altre vie, fosse riuscito ad impadronirsi di K_{ab} .

Considerazioni simili possono essere fatte per B se questo processo riutilizza la quantità k_b .

ESERCIZIO 3

Quesito A. Il protocollo non garantisce l'identificazione. Supponiamo che un avversario A intercetti una coppia challenge-response. Più precisamente, A intercetta la challenge e la frame f che trasporta la relativa response. Tale frame oltre a response trasporta anche il vettore di inizializzazione v utilizzato per cifrare la challenge. Dalla challenge (testo in chiaro) e dalla response (crittogramma) è possibile ricavare il keystream $\{z_i(v)\}$ facendo l'or-esclusivo tra le due quantità. A questo punto l'avversario conosce una coppia (vettore di inizializzazione, keystream) $(v, \{z_i(v)\})$ che può riutilizzare in (un numero indefinito di) altre esecuzioni del protocollo di identificazione.

Quesito B. Come nel caso precedente l'avversario riesce a violare il protocollo riutilizzando una coppia $(v, \{z_i(v)\})$. Il keystream può essere ricavato come nel caso precedente mentre v può essere ricavato dalla frame che trasporta la challenge. Differentemente a prima, adesso è AP che seleziona v . L'avversario quindi deve costruirsi un dizionario $DIZ = \{(v, \{z_i(v)\}) \mid v \in V_{24}\}$, con V_{24} l'insieme di tutte le sequenze di 24 bit. DIZ ha 2^{24} voci, ciascuna di $sizeof(v) + sizeof(\{z_i(v)\})$ byte. La quantità v occupa 3 byte. Il keystream $\{z_i(v)\}$ ha per definizione la stessa dimensione della challenge, cioè $128/8 = 16$ byte. Ne segue quindi che una voce del dizionario occupa 19 byte. Ne segue perciò che il DIZ ha una dimensione pari a $19 \times 2^{24} \cong 20$ Mbyte.

Nome e Cognome _____ Matricola _____

ESERCIZIO 1**PUNTI: 14 (3, 3, 2, 3, 3)**

Con riferimento al sistema di crittografia One-time Pad, il candidato, con precisione matematica e proprietà di linguaggio,

1. descriva gli algoritmi di generazione della chiave, di cifratura e di decifratura;
2. specifichi le condizioni sotto le quali il cifrario è perfetto;
3. illustri le implicazioni pratiche di tali condizioni.

Siano $P = \text{"MARIOROSSIO850EURO"}$, $K = \text{"5RTIOX1LQB39DEMZAN"}$,

4. si determini C sapendo
 - che $C[i]$, $P[i]$ e $K[i]$ sono la rappresentazione dell' i -esimo carattere di C , P e K , rispettivamente;
 - che il generico carattere è rappresentato dall'intero che esprime la sua posizione, a partire da zero, nell'alfabeto $\mathcal{A} = \{\text{'A'}, 'B'}, \dots, \text{'Z'}, '0', '1', \dots, '9'\}$;
 - che $C[i] = P[i] \oplus K[i]$ per ogni carattere di P .
5. si determini la probabilità che un avversario, operando sul solo testo cifrato, riesca ad incrementare la cifra più significativa dell'importo sapendo che tale importo è minore di 1000 euro.

SOLUZIONE.

Punti 1–3. Vedere il materiale didattico.

Punto 4. Eseguire le somme modulo 31.¹

Punto 5. L'avversario ha la certezza del successo del suo attacco. Sapendo che l'importo è minore di 1000 euro, l'avversario sa che la cifra più significativa è rappresentata dal carattere $p = '0'$. Conoscendo il carattere c del crittogramma corrispondente a p ('Q'), l'avversario è in grado di determinare il carattere k della chiave associato a p e c come $p \oplus c$. Tale carattere è '3'. A questo punto l'avversario può calcolare il carattere c' da sostituire nel crittogramma al posto di 'Q', $c' = k \oplus '1' = 'R'$.

Più semplicemente si poteva osservare che $c' = p \oplus 1 \oplus k = c \oplus 1$.

ESERCIZIO 2**PUNTI: 8 (4, 4)**

1. Bob riceve il messaggio $\langle \text{Alice}, m, \Pi, \sigma \rangle$ e verifica con successo la firma digitale σ di m per mezzo della chiave pubblica Π . Indicare quale delle seguenti conclusioni Bob può correttamente trarre, motivando la scelta:

¹ Oppure modulo 36 se si considera l'alfabeto inglese. Noi consideriamo quello italiano.

- a) Il messaggio m è stato firmato con la chiave privata di Alice;
 - b) Il messaggio m è stato firmato con la chiave privata corrispondente a Π ;
 - c) Il messaggio m è stato firmato da Alice.
2. Sia T un'autorità di certificazione di fiducia di Bob, di cui Bob conosce la chiave pubblica Π_T . Sia inoltre $X(T, A)$ un certificato rilasciato da T ad Alice. Bob riceve il messaggio $\langle A, m, \sigma, X(T, A) \rangle$ e verifica con successo le firme digitali. Quale delle precedenti conclusioni Bob può adesso correttamente trarre? Motivare la scelta.

SOLUZIONE.

Quesito 1. Bob può giungere alla conclusione b.

Quesito 2. Bob può giungere alla conclusione a.

ESERCIZIO 3

PUNTI: 10 (3, 4, 3)

Con riferimento a Kerberos 5, il candidato

- 1. illustri il protocollo semplificato;
- 2. lo analizzi con la logica BAN;
- 3. discuta l'impatto che il *ticket lifetime* e l'*authenticator lifetime* hanno sulla sicurezza del protocollo.

SOLUZIONE. Vedere il materiale didattico.

LAUREA SPECIALISTICA IN INGEGNERIA INFORMATICA
SICUREZZA NELLE RETI
Appello del 31 Gennaio 2006

SOLUZIONE

ESERCIZIO 1

ESERCIZIO 2

ESERCIZIO 3

Sicurezza nelle Reti

Appello del 7 Luglio 2006

Nome e Cognome _____ Matricola _____

QUESITO 1

PUNTI: 12 (5, 1, 2, 4)

Sia W un borsellino elettronico che memorizza informazioni relative ai clienti, come nome, indirizzo e numero di carta di credito, ed esegue pagamenti per loro conto. Un cliente C viene identificato da W per mezzo di un PIN, un numero segreto su p bit condiviso tra C ed W . Sia PK_W la chiave pubblica del server W , su k bit, che si suppone pubblicamente nota.

Sia D la descrizione (una stringa di caratteri) della merce che C vuole acquistare, sia nota a W oltre che a C . Un possibile protocollo di autorizzazione dell'acquisto è costituito dai seguenti messaggi:

M1 $W \rightarrow C$: W, tid, D

M2 $C \rightarrow W$: $C, E_W(tid, D, PIN)$

dove tid è l'identificatore unico di transazione generato da W ed $E_X(m)$ denota la cifratura della quantità m con la chiave pubblica di X . Il candidato risponda alle seguenti domande motivando le risposte.

1. Il protocollo garantisce la confidenzialità della quantità PIN rispetto ad ciphertext-only attack? Si determini il tempo medio necessario per tale attacco nel caso che $k = 1024$, $p = 4$ ed il tempo necessario ad eseguire una cifratura/decifratura è di circa 50ms.

SOLUZIONE. In M2 le quantità tid e D non sono segrete (lette in M1). Inoltre PK_W è pubblica. Per cui si può fare una ricerca esaustiva sul PIN. Il tempo medio è $(50 \times 10^4)/2 = 250000$ ms = 250 s = 6 minuti e 10 secondi

2. Tale attacco può essere condotto off-line?

SOLUZIONE. Sì.

3. Tenendo conto della risposta al punto 2, il server W può attribuire il messaggio M2 al customer C ?

SOLUZIONE. NO.

4. Nel caso la risposta alla domanda 3 sia negativa, apportare una modifica al protocollo in modo da garantire l'autenticità del customer senza però assegnare alcuna coppia di chiavi pubblica-privata al customer.

SOLUZIONE. Basta che il customer concateni un numero random di sua scelta alle quantità tid , D , PIN nel messaggio M2. Il numero random deve avere una lunghezza sufficiente da rendere praticamente impossibile un attacco esaustivo ai dati.

QUESITO 2

PUNTI: 8 (5, 3)

Con precisione matematica e proprietà di linguaggio, si definisca il *true random cipher* e ne discuta i problemi relativi ad una pratica realizzabilità.

SOLUZIONE. Vedere materiale didattico

QUESITO 3

PUNTI: 12 (3, 3, 2, 4)

1. Si spieghi con precisione matematica e proprietà di linguaggio quando un cifrario viene detto *sicuro dal punto di vista computazionale*.

SOLUZIONE. Vedere materiale didattico.

2. Si definiscano i due attacchi: *known-plaintext attack* e *chosen-plaintext attack*.

SOLUZIONE. Vedere materiale didattico.

Si consideri il cifrario a blocchi FEAL- N caratterizzato dai seguenti parametri: block size $n = 64$ bit, key size $k = 64$ e numero di round $N = 4, 6, 8, 16, 24, 32$. La Tabella 1 specifica la resistenza di FEAL a vari attacchi.

3. Si vuole garantire la confidenzialità delle informazioni per almeno un giorno rispetto ad un avversario capace di un *known-plaintext attack*. Si indichi quali cifrari sono da considerarsi insicuri in tal caso.

SOLUZIONE. Si scarta FEAL- N per N uguale a 4, 6 ed 8. Gli altri cifrari possono essere utilizzati perché l'attacco più efficiente è di tipo *chosen-plaintext attack* ma l'avversario non è capace di questo tipo di attacco per ipotesi.

4. Si indichi quali cifrari sono da considerarsi insicuri nel caso che si voglia garantire la confidenzialità delle informazioni per almeno un mese rispetto ad un avversario che è capace di un *chosen-plaintext attack off-line*,¹ che dispone di hardware convenzionale (un PC ad esempio), e che riesce ad eseguire operazioni di cifratura e decifratura in 1 ms.

SOLUZIONE. Si scarta FEAL 16 perché richiede circa 8 Gbytes di memoria per memorizzare offline i *chosen pairs* ed impiega circa 106 secondi (12 gg) per condurre l'attacco.

Tabella 1. Attacchi a FEAL. LC sta per *linear cryptanalysis* e DC sta per *differential cryptanalysis*.

attack method	data complexity		storage complexity	processing complexity
	known	chosen		
FEAL-4 – LC	5	—	30 Kbytes	6 minutes
FEAL-6 – LC	100	—	100 Kbytes	40 minutes
FEAL-8 – LC FEAL-8 – DC	2^{24}	2^7 pairs	280 Kbytes	10 minutes 2 minutes
FEAL-16 – DC	—	2^{29} pairs		2^{30} operations
FEAL-24 – DC	—	2^{45} pairs		2^{46} operations
FEAL-32 – DC	—	2^{66} pairs		2^{67} operations

¹ L'avversario accumula i *chosen pair* necessari e poi li utilizza come dati dell'algoritmo di crittoanalisi.

Sicurezza nelle Reti

Appello del 14 Luglio 2006

SOLUZIONE

QUESITO 1

PUNTI: 8

In un cifrario C esistono un messaggio m ed un crittogramma c tali che $\text{Prob}(M = m) = p$, con $p < 1/4$, e $\text{Prob}(M=m|C=c) = 1-p$. Spiegare se C può essere un cifrario perfetto e le conseguenze per un crittoanalista per la coppia (m, c) indicata.

Affinché il cifrario sia perfetto bisogna che $p = 1 - p$. Questa uguaglianza non è soddisfatta per $p < 1/4$ e perciò il cifrario non è perfetto. Questo implica che se l'avversario vede passare in rete il crittogramma c allora può concludere che è stato trasmesso il messaggio m con una probabilità $1 - p$. Siccome questa probabilità è maggiore di p , la probabilità con cui viene trasmesso m , allora l'avversario ha guadagnato dall'osservazione del testo cifrato maggiori informazioni su m .

QUESITO 2

PUNTI: 10 (8, 2)

A e B utilizzano un crittosistema simmetrico $E()$ ed una funzione hash con chiave $h()$. A e B utilizzano inoltre le chiavi segrete condivise K e K' con il crittosistema e la funzione hash, rispettivamente. Infine A e B utilizzano un meccanismo contatore-finestra (come quello di IPsec) di supporto ad un servizio anti-replay. Supponendo che il formato dei messaggi sia $m = (c, x, d)$, con x valore del contatore del mittente, specificare quale, o quali, dei seguenti casi fornisce il servizio anti-replay:

1. $c = E(K, m)$; $d = h(K', x)$
2. $c = E(K, m \parallel x)$; $d = h(K', x)$
3. $c = E(K, m)$; $d = h(K', c \parallel x)$

In caso di soluzioni equivalenti, indicare quella che permette di realizzare il servizio anti-replay con il minore carico computazionale dal punto di vista del ricevitore.

La prima soluzione non garantisce l'anti-replay perché m ed x non sono "indissolubilmente" (crittograficamente) legati tra di loro. La seconda e la terza soluzione garantiscono anti-replay con una differenza dal punto di vista dell'overhead computazionale. Nella seconda, la verifica dell'anti-replay richiede la decifratura del messaggio. Perciò saranno inutilmente decifrati anche i messaggi destinati ad essere scartati. Nella terza, la verifica viene fatta sul testo cifrato. Quindi la decifratura verrà eseguita solo dei messaggi che sono accettati.

QUESITO 3

PUNTI: 12 (4, 4, 4)

Con riferimento al sistema RSA, il candidato, con precisione matematica e proprietà di linguaggio,

1. descriva gli algoritmi di generazione della chiave, di cifratura e di decifratura;
2. ne discuta la "sicurezza" (relazione tra RSA ed un problema complesso); ed infine
3. illustri perché il riutilizzo del modulo può portare ad un *common modulus attack*.

Vedere materiale didattico.

Sicurezza nelle Reti

Appello del 3 Novembre 2006

Nome e Cognome _____ Matricola _____

QUESITO 1**PUNTI: 12 (6, 3, 3)**

Con proprietà di linguaggio e precisione matematica, si risponda alle seguenti domande.

1. Si definisca la funzione hash con chiave (Message Authentication Code, MAC).
2. Si consideri una funzione hash con chiave h caratterizzata come segue: 1) la chiave è su t bit; 2) l'output è su n bit; 3) l'output della funzione hash può essere considerato una variabile aleatoria uniformemente distribuita.
 - i. Un avversario ha a disposizione una coppia $(x, h_k(x))$ e tenta un attacco esaustivo allo spazio candidato. Si chiama *falso positivo*, una chiave z , diversa da k , tale che $h_z(x) = h_k(x)$. Qual è il numero medio di falsi positivi che ci si aspetta da un attacco esaustivo allo spazio delle chiavi? (si assuma che $2^t \gg 1$ e $2^n \gg 1$).
 - ii. Quante coppie $(x_i, h_k(x_i))$ sono necessarie per eliminare il problema dei falsi positivi ovvero di ridurre il loro numero aspettato ad un valore minore di uno?

SOLUZIONE

Quesito 1. Vedere appunti.

Quesito 2. Con chiavi a t bit si possono fare 2^t tentativi: 1) calcolare $h_i(x)$ e 2) verificare se il valore ottenuto è uguale a $h_k(x)$ per ogni valore di i , $0 \leq i < 2^t$. Uno di questi tentativi produrrà alla chiave cercata. Gli altri $2^t - 1$ tentativi possono produrre un falso positivo. Siccome la funzione hash produce un output perfettamente random per ipotesi, allora per ogni tentativo si ha una probabilità pari a 2^{-n} di produrre un falso positivo. Per cui mediamente ci si aspettano $(2^t - 1)/2^n$ falsi positivi.

Quesito 3. Supponiamo adesso di avere r coppie $(x_i, h_k(x_i))$, $1 \leq i \leq r$. Nei 2^t tentativi, ce ne sarà uno, quello relativo alla chiave k . Per avere un falso positivo z bisogna che $h_z(x_i) = h_k(x_i)$, $\forall i \in [1, r]$. Data una chiave z , la probabilità che questo accada è data dalla probabilità composta ed è perciò pari a $\prod_{i=1}^r \mathcal{P}(h_z(x_i) = h_k(x_i)) = 2^{-rn}$. Ne segue che il numero medio di falsi positivi è $(2^t - 1) \times 2^{-rn} \approx 2^{t-rn}$. Per escludere la possibilità di falsi positivi basta imporre $2^{t-rn} < 1$ che è verificata per $r > t/n$.

QUESITO 2**PUNTI: 12 (3, (3, 3), 3)**

Si consideri il seguente protocollo di distribuzione delle chiavi.

M1 $A \rightarrow B: E_e(k)$

M2 $B \rightarrow A: S_B(E_e(k))$

dove k è una chiave di sessione, e è una chiave per comunicare in maniera confidenziale con B ed S è una firma digitale. Oltre a distribuire una chiave di sessione, il protocollo ha l'obiettivo di identificare B rispetto ad A (ma non viceversa). Il candidato risponda alle seguenti domande con precisione e proprietà di linguaggio.

1. Sotto quali ipotesi il protocollo garantisce l'identificazione di B rispetto ad A ?
2. Si assuma che E ed S siano realizzati per mezzo dell'algoritmo RSA.
 - a. È possibile utilizzare la stessa coppia di chiavi pubblica (e_B, n_B) e privata (d_B, n_B) sia per E sia per S ?
 - b. Nel caso si utilizzino due coppie di chiavi diverse quale relazione deve sussistere tra i moduli? Si indichi con n_e e con n_s i moduli per il cifrario e per la firma digitale rispettivamente.
3. Si modifichi il protocollo in modo da utilizzare, come crittografia asimmetrica, solo il cifrario E .

QUESITO 3**PUNTI: 6**

Si descriva il processo di generazione dell'intestazione ESP.

SICUREZZA NELLE RETI

Appello del 1 Febbraio 2007

Nome e Cognome _____ Matricola _____

ESERCIZIO 1

PUNTI:10

Un sistema utilizza un cifrario simmetrico (E, D) caratterizzato da una chiave di $k = 64$ bit e da un blocco $n = 64$ bit. Sia $\mathcal{A}$ un attacco di tipo *known-plaintext*, con una complessità dei dati pari a 2^{35} ed una complessità di calcolo pari a 2^{36} .

Sia N un avversario con una capacità di calcolo pari a 1 Mcryptops/s,¹ dotato di 1000 Gbyte di memoria e capace di eseguire off-line l'attacco $\mathcal{A}$, procurandosi in un mese le coppie necessarie.

1. Si discuta la resistenza del cifrario alla a) ricerca esaustiva delle chiavi e b) all'attacco $\mathcal{A}$, sapendo che il testo cifrato deve rimanere segreto per almeno un anno.
2. Dalla discussione precedente si indichi una politica di rinnovo delle chiavi.

ESERCIZIO 2

PUNTI: 10

Sia PK la chiave pubblica del server S e sia PIN un segreto condiviso tra il server S ed il cliente C . Si definisca un protocollo di distribuzione delle chiavi che, al termine della sua esecuzione, soddisfi i seguenti requisiti:

1. il cliente ed il server condividono una chiave segreta di sessione K ;
2. il cliente ha identificato il server ed ha la prova che il server possiede la chiave K ;
3. il server ha identificato il cliente ed ha la prova che il cliente possiede la chiave K ;
4. il protocollo è resistente ad attacchi di replay.

Tali requisiti devono essere soddisfatti assumendo che 1) per quanto riguarda la crittografia asimmetrica, il server ed il cliente dispongono solo di un cifrario (ovvero la firma digitale non è disponibile); 2) il PIN è costituito da quattro cifre decimali.

Il candidato definisca il protocollo in forma idealizzata, formalizzando sia le proprietà che il protocollo deve soddisfare sia le ipotesi sulle quali il protocollo si basa. Successivamente il candidato dia una possibile codifica dei messaggi del protocollo.

ESERCIZIO 3

PUNTI: 10

Il candidato illustri il problema del clogging in Diffie-Hellman ed il meccanismo di anti-clogging di Oakley.

¹ Il termine *cryptops* sta per operazioni di crittoanalisi.

SICUREZZA NELLE RETI

Appello del 1 Febbraio 2007

SOLUZIONE

ESERCIZIO 1

Ricerca esaustiva delle chiavi. Questo attacco richiede, mediamente, 2^{63} operazioni. Siccome, l'avversario N è in grado di eseguire 1 Mcryptops, allora il tempo necessario per eseguire questo attacco è $t = \frac{2^{63}}{10^6}$ secondi che corrisponde a circa ventinovemila anni.

Attacco A. Questo attacco ha una complessità di calcolo pari a 2^{36} operazioni che, con le risorse a disposizione dell'avversario, richiedono un tempo pari a $t = \frac{2^{36}}{10^6} s \cong 6872$ s, ovvero circa 115 minuti.

Per l'attacco sono necessarie 2^{35} coppie che richiedono una quantità di memoria $s = 2 \times 2^{35} \times 8 = 2^{39}$ byte che equivale a 512 Gbyte. L'avversario dispone delle risorse necessarie. Per cui, l'avversario in poco più di un mese riesce a procurarsi le coppie per l'attacco A ed ad eseguire tale attacco ottenendo la chiave. Ne segue che l'avversario N è in grado di violare il requisito di confidenzialità.

Politica di rinnovo delle chiavi. Sotto le ipotesi fatte ed i risultati raggiunti finora è conveniente rinfrescare la chiave con una frequenza superiore ad una volta al mese in modo da non dare all'avversario la possibilità di raccogliere le coppie necessarie all'attacco.

ESERCIZIO 2

Obiettivi.

- O1 $S \models C \leftrightarrow S$
- O2 $S \models C \models C \leftrightarrow S$
- O3 $C \models S \models C \leftrightarrow S$

Ipotesi.

- A1 $C \models^{\text{PK}} a$
- A2 $C \models C \leftrightarrow S$
- A3 $C \models \#(C \leftrightarrow S)$
- A4 $S \models \#(n_s)$
- A5 $S \models C \Rightarrow (C \leftrightarrow S)$
- A6 $S \models (C \overset{\text{PIN}}{E} S)$
- A7 $C \models (C \overset{\text{PIN}}{E} S)$

Protocollo idealizzato.

- M1 $S \rightarrow C: n_s$
- M2 $C \rightarrow S: \left\{ \left\langle C \overset{K}{\leftrightarrow} S \right\rangle_{\text{PIN}}, n_s \right\}_{\text{PK}}$
- M3 $S \rightarrow C: \left\{ C \overset{K}{\leftrightarrow} S \right\}_K$

SICUREZZA NELLE RETI

Appello del 1 Febbraio 2007

Analisi.

Alla ricezione di M2, $S \models C \stackrel{K}{\leftrightarrow} S$ (O2) in virtù di A6 e A4. Da O2 e A5, $S \models C \stackrel{K}{\leftrightarrow} S$ (O1). Alla ricezione di M3, $C \models S \stackrel{K}{\leftrightarrow} S$ (O3) sulla base di A2 ed A3.

Protocollo reale.

M1 $S \rightarrow C: S, C, n_s$

M2 $C \rightarrow S: \{S, C, PIN, K, n_s\}_{PK}$

M3 $S \rightarrow C: \{S, C\}_K$

ESERCIZIO 3

Vedere appunti.

Nome e Cognome _____ Matricola _____

ESERCIZIO 1

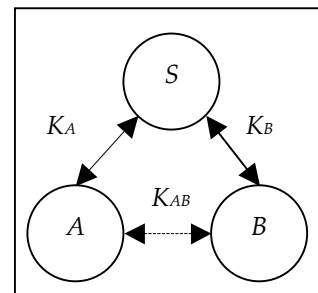
punti:7

Con proprietà di linguaggio e precisione matematica il candidato dia la definizione di cifrario a blocchi ed illustri le problematiche relative alla realizzazione di un cifrario a blocchi perfettamente random.

ESERCIZIO 2

punti: 15

Si consideri il sistema rappresentato in figura in cui il server S costituisce la terza entità fidata per lo scambio delle chiavi tra A e B . A e B condividono con S le chiavi segrete K_A e K_B , rispettivamente. Inoltre, S ha il proprio clock sincronizzato con quello di A e di B .



Utilizzando la logica BAN, il candidato progetti un protocollo per la distribuzione di una chiave di sessione K_{AB} che soddisfi i seguenti requisiti:

1. entrambi A e B contribuiscono alla chiave di sessione con le quantità a e b rispettivamente in modo tale che $K_{AB} = h(a, b)$, con $h()$ funzione hash;
2. alla fine del protocollo ciascun partecipante ha la prova che l'altro dispone della chiave di sessione;
3. il protocollo non è soggetto a replay.

Suggerimento. Potrebbe essere utile estendere la logica BAN con il seguente postulato:

$$\frac{A \models A \xrightarrow{a} B, A \models A \xrightarrow{b} B, K = h(a, b)}{A \models A \xleftrightarrow{K} B}$$

ESERCIZIO 3

punti:8

Con proprietà di linguaggio e precisione matematica il candidato il candidato

1. illustri il protocollo Diffie-Hellmann e
2. ne discuta le proprietà di sicurezza.

SOLUZIONE

ESERCIZIO 1

Vedi appunti.

ESERCIZIO 2

Protocollo reale.

$$M1 \quad A \rightarrow S \quad A, B, \{a, T_a\}_{K_A}$$

$$M2 \quad S \rightarrow B \quad A, \{a, T_s\}_{K_B}$$

$$M3 \quad B \rightarrow S \quad \{b, T_b\}_{K_B}$$

$$M4 \quad S \rightarrow A \quad \{b, T'_s\}_{K_A}$$

$$M5 \quad A \rightarrow B \quad \{A, B\}_{K_{AB}}$$

$$M6 \quad B \rightarrow A \quad \{B, A\}_{K_{AB}}$$

Protocollo idealizzato.

$$M1 \quad A \rightarrow S \quad \left\{ A \stackrel{a}{\rightleftharpoons} B, T_a \right\}_{K_A}$$

$$M2 \quad S \rightarrow B \quad A, \left\{ A \models A \stackrel{a}{\rightleftharpoons} B, T_s \right\}_{K_B}$$

$$M3 \quad B \rightarrow S \quad \left\{ A \stackrel{b}{\rightleftharpoons} B, T_b \right\}_{K_B}$$

$$M4 \quad S \rightarrow A \quad \left\{ B \models A \stackrel{b}{\rightleftharpoons} B, T'_s \right\}_{K_A}$$

$$M5 \quad A \rightarrow B \quad \left\{ A \stackrel{K_{AB}}{\leftrightarrow} B \right\}_{K_{AB}}$$

$$M6 \quad B \rightarrow A \quad \left\{ A \stackrel{K_{AB}}{\leftrightarrow} B \right\}_{K_{AB}}$$

Ipotesi

$$1 \quad A \models A \stackrel{K_A}{\leftrightarrow} S, S \models A \stackrel{K_A}{\leftrightarrow} S, B \models B \stackrel{K_B}{\leftrightarrow} S, S \models B \stackrel{K_B}{\leftrightarrow} S$$

$$2 \quad A \models A \stackrel{a}{\rightleftharpoons} B, B \models A \stackrel{b}{\rightleftharpoons} B$$

$$3 \quad A \models \# \left(A \stackrel{a}{\rightleftharpoons} B \right), A \models \# (T'_s)$$

$$4 \quad B \models \# \left(A \stackrel{b}{\rightleftharpoons} B \right), B \models \# (T_s)$$

$$5 \quad S \models \# (T_a), S \models \# (T_b)$$

$$6 \quad \forall X, A \models S \Rightarrow B \models X, A \models B \Rightarrow A \stackrel{b}{\rightleftharpoons} B$$

$$7 \quad \forall X, B \models S \Rightarrow A \models X, B \models A \Rightarrow A \stackrel{a}{\rightleftharpoons} B$$

L'analisi consiste in una meccanica applicazione dei postulati a partire dalle ipotesi.

ESERCIZIO 3

Vedi appunti.

Nome e Cognome _____ Matricola _____

ESERCIZIO 1

Punti:7

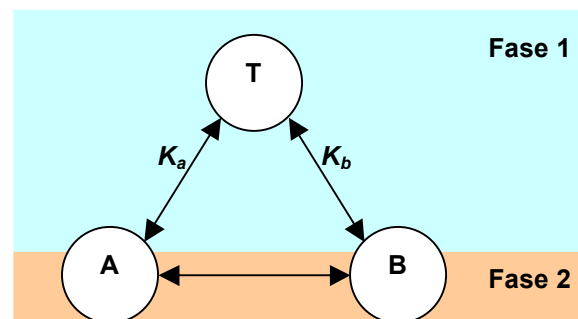
Con proprietà di linguaggio e precisione matematica, il candidato

- a) enunci le proprietà di *preimage resistance*, *2nd-preimage resistance* e *collision resistance* di una funzione hash sicura;
- b) il candidato indichi il limite superiore della sicurezza (in termini di complessità) di una funzione hash con m bit di output.

ESERCIZIO 2

punti: 15

Con riferimento al sistema in figura, si progetti un protocollo di distribuzione delle chiavi in *due fasi* basato su Diffie-Hellmann con parametri pubblici p e g . Nella prima fase, A e B interagiscono con la Certification Authority T e stabiliscono una *chiave di autenticazione* AK_{ab} che ha un *periodo di validità* pari a Δ secondi. Nella seconda fase, A e B interagiscono tra di loro e stabiliscono una *chiave di sessione* SK_{ab} utilizzando AK_{ab} . Si assuma che: a) i clock siano sincronizzati e b) A e B condividano con T le chiavi K_a e K_b rispettivamente.



ESERCIZIO 3

punti:8

Con proprietà di linguaggio il candidato descriva il meccanismo a finestra anti-replay di IpSec.

Soluzione

ESERCIZIO 1

Vedi appunti.

ESERCIZIO 2

Fase 1.

1. $A \rightarrow T \quad \{A, B, t_{a_1}, Y_{a_1}\}_{K_a}$
2. $T \rightarrow B \quad \{A, B, t_{t_1}, Y_{a_1}, \Delta\}_{K_b}$
3. $B \rightarrow T \quad \{B, A, t_{b_1}, Y_{b_1}\}_{K_b}$
4. $T \rightarrow A \quad \{B, A, t_{t_2}, Y_{b_1}, \Delta\}_{K_a}$

Al termine della prima fase la chiave di autenticazione è $AK_{ab} = Y_{a_1}^{b_1} \bmod p = Y_{b_1}^{a_1} \bmod p$.

Fase 2.

1. $A \rightarrow B \quad Y_{a_2}, \{Y_{a_2}, t_{a_2}\}_{AK_{ab}}$
2. $A \rightarrow B \quad Y_{b_2}, \{Y_{b_2}, t_{b_2}\}_{AK_{ab}}$

Al termine della seconda fase la chiave di sessione è $SK_{ab} = Y_{a_2}^{b_2} \bmod p = Y_{b_2}^{a_2} \bmod p$.

ESERCIZIO 3

Vedi appunti.

Nome e Cognome _____ Matricola _____

ESERCIZIO 1

punti: 6

Con proprietà di linguaggio e precisione matematica, il candidato discuta se i seguenti cifrari sono perfetti (secondo la teoria di Shannon)

- un cifrario a chiave pubblica;
- il cifrario a blocchi Figura 1 (sinistra) con p testo in chiaro, c testo cifrato, $n = 64$, e $k = 56$.
- il cifrario a caratteri in Figura 1 (destra) con p_i e c_i rispettivamente i -esimo bit del testo in chiaro e del testo cifrato e $k = 56$.

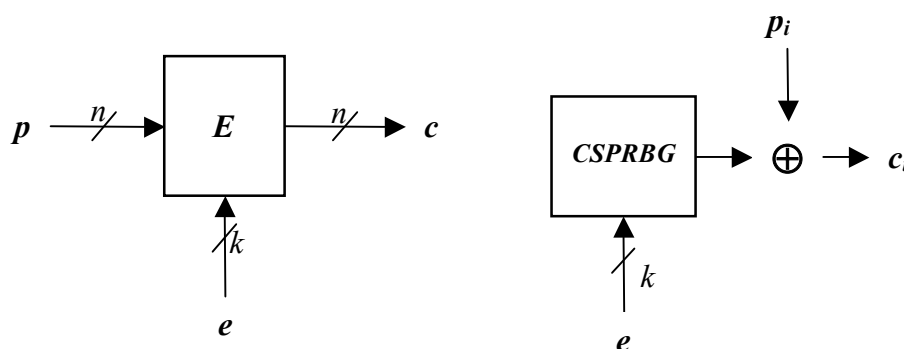


Figura 1.

ESERCIZIO 2

punti: 15

Con riferimento al sistema di comunicazione in Figura 2, definire un protocollo di distribuzione delle chiavi che soddisfi i seguenti requisiti:

- A e B sono convinti che K_{ab} è la chiave di sessione;
- A è convinto che B disponga di K_{ab} e viceversa;
- il protocollo non è soggetto a *replay attack*;

sotto i seguenti vincoli

- A e B condividono una chiave segreta, rispettivamente con K_a e K_b , con T ;
- A e B considerano T competente nella generazione delle chiavi;
- i clock non sono sincronizzati.

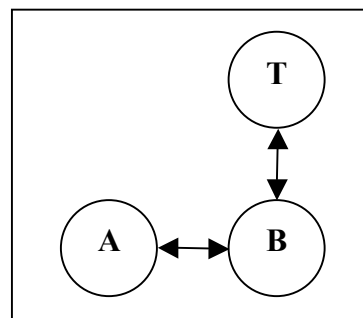


Figura 2.

ESERCIZIO 3

punti: 8

Si descriva il meccanismo anti-replay di IpSec AH.

SICUREZZA NELLE RETI

Appello del 24 luglio 2009

Esercizio 1

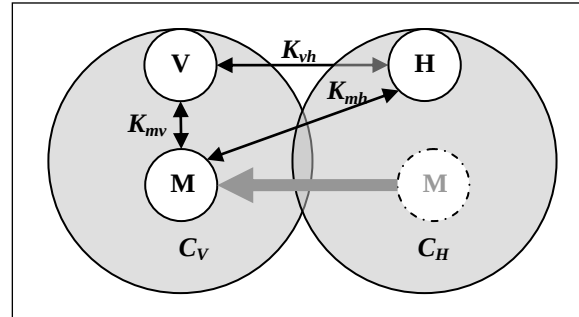
punti: 10

Con proprietà di linguaggio e precisione matematica si discuta la sicurezza dell'algoritmo RSA.

Esercizio 2

punti: 12

Si consideri il sistema semplificato di *roaming* riportato in figura in cui una stazione mobile M registrata presso l'*home server* H si trova nella cella C_V gestita dal server *visited server* V . Per garantire la comunicazione sicura della stazione mobile M è necessario che questa stabilisca un canale sicuro (la chiave simmetrica K_{vm}) con il visited server V . A tale proposito si assuma che:



- A. in virtù della registrazione, la stazione mobile M ed l'*home server* H condividono la chiave k_{mh} .
- B. i server H e V fanno parte dell'infrastruttura e pertanto condividono la chiave k_{vh} ;
- C. la stazione mobile M ed i server H , V utilizzano lo stesso cifrario; ed infine
- D. i loro clock non sono sincronizzati.

Progettare un protocollo di distribuzione delle chiavi che soddisfi i seguenti requisiti:

1. permette l'autenticazione mutua di M e V quando M entra nella cella C_V ;
2. permette di distribuire una chiave di sessione k_{mv} tra M e V ;
3. fornisce la prova a V che M possiede k_{mv} e viceversa;
4. mantiene la segretezza della chiave k_{mh} ;
5. è resistente ad attacchi di replay.

Il candidato argomenti per mezzo della logica BAN che il protocollo proposto soddisfa i requisiti posti.

Esercizio 3

punti: 8

Si descrivano le informazioni minime che devono essere contenute in un certificato digitale ed i principali obblighi che un'autorità di certificazione deve assolvere per il rilascio di tale certificato.

Soluzione

Risposta a. Il protocollo garantisce la confidenzialità. Per determinare il valore di K_{AB} è necessario conoscere le quantità k_a e k_b . Tuttavia queste quantità viaggiano in rete in forma cifrata.

Risposta b. Il protocollo è una versione semplificata del protocollo Needham-Schroeder a chiave pubblica. Il protocollo garantisce la *key authentication*. Formalmente: $A \models B \models A \xrightarrow{k_b} B$ e $B \models A \models A \xrightarrow{k_a} B$.

Risposta c. Come si evince dalle formule sopra, il protocollo garantisce anche la key confirmation.

Risposta d. Se l'ipotesi (i) non è verificata, il protocollo non garantisce la proprietà di key authentication. Supponiamo che la quantità k_a sia riutilizzata da A e che un avversario M abbia registrato i messaggi M1 ed M2 relativi all'esecuzione del protocollo in cui k_a è stata utilizzata la prima volta. L'avversario M potrebbe eseguire il seguente attacco:

- induce A ad iniziare una nuova istanza del protocollo con B;
- quando A invia il messaggio M1' relativo alla nuova esecuzione del protocollo, contenente la quantità riutilizzata k_a , l'avversario M determina che $M1=M1'$, e risponde con M2. Alla ricezione di questo messaggio il processo A crede di parlare effettivamente con B.

Si noti che questo attacco ha come effetto collaterale il riutilizzo della vecchia chiave di sessione K_{ab} (la quantità k_b è contenuta nel messaggio M2 replicato da M). L'avversario M potrebbe non conoscere tale chiave ma potrebbe comunque replicare vecchi messaggi relativi alla sessione K_{ab} che A considererebbe come provenienti da B. Il danno sarebbe massimo se M , per altre vie, fosse riuscito ad impadronirsi di K_{ab} .

Considerazioni simili possono essere fatte per B se questo processo riutilizza la quantità k_b .

SICUREZZA NELLE RETI

Appello del 18 settembre 2009

Esercizio 1

punti: 12

Con proprietà di linguaggio e precisione matematica si definiscano le proprietà one-way, weak collision resistance e strong collision resistance di una funzione hash sicura e se discuta la loro rilevanza nell'ambito della firma digitale.

Esercizio 2

punti: 12

In un sistema cliente-servitore, sia Π la *chiave pubblica* del server S e sia PIN un *segreto condiviso* tra il server S ed il cliente C . Si assuma inoltre che la chiave Π sia nota al cliente C .

QUESITO 1. Si progetti un protocollo di distribuzione delle chiavi che, al termine della sua esecuzione, soddisfi i seguenti requisiti:

1. il cliente ed il server condividono una *chiave segreta di sessione* K ;
2. il cliente ha identificato il server ed ha la prova che il server possiede la chiave K ;
3. il server ha identificato il cliente ed ha la prova che il cliente possiede la chiave K ;
4. il protocollo è resistente ad attacchi di *replay*.

Tali requisiti devono essere soddisfatti assumendo che: a) gli orologi del cliente e del server non siano sincronizzati e b) per quanto riguarda la crittografia a chiave pubblica, il server ed il cliente dispongono solo di un cifrario ma non della firma digitale.

Il candidato argomenti brevemente ma con precisione matematica e proprietà di linguaggio che il protocollo proposto soddisfa i requisiti posti.

Quesito 2. Modificare il protocollo assumendo che gli orologi del cliente e del server siano sincronizzati.

QUESITO 3. Siccome il PIN è un segreto condiviso tra il server ed il client, tale quantità potrebbe essere utilizzata come chiave simmetrica, ovvero per derivarne una, al fine di garantire i requisiti di confidenzialità ed autenticità della chiave di sessione. Il candidato argomenti brevemente ma con precisione matematica e proprietà di linguaggio se questa è un'opzione sicura.

Esercizio 3

punti: 6

Si descrivano le informazioni minime che devono essere contenute in un certificato digitale ed i principali obblighi che un'autorità di certificazione deve assolvere per il rilascio di tale certificato.

SICUREZZA NELLE RETI

Appello del 14 Gennaio 2010

Esercizio 1

punti: 10

Con proprietà di linguaggio e precisione matematica il candidato (a) definisca il cifrario perfetto secondo Shannon e (b) dimostri che in tale cifrario il numero delle chiavi non può essere inferiore al numero dei messaggi.

Esercizio 2

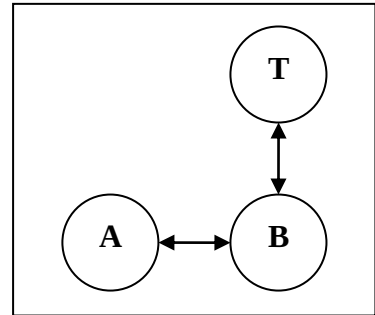
punti: 12

Con riferimento al sistema di comunicazione in figura, usando la logica BAN, definire un protocollo di distribuzione delle chiavi che soddisfi i seguenti requisiti:

1. A e B sono convinti che K_{ab} è la chiave di sessione;
2. A è convinto che B disponga di K_{ab} e viceversa;
3. il protocollo non è soggetto a *replay attack*;

sotto i seguenti vincoli

- A. A e B condividono una chiave segreta, rispettivamente con K_a e K_b , con T ;
- B. A e B considerano T competente nella generazione delle chiavi;
- C. i clock non sono sincronizzati.



Esercizio 3

punti: 8

Il candidato (a) descriva il problema del Denial of Service nel protocollo Diffie-Hellman e (b) discuta la soluzione proposta nel protocollo di Oakley.

Soluzione

Esercizio 2

$$M\ 1 \quad A \rightarrow B : \quad A, B, n_a$$

$$M\ 2 \quad B \rightarrow T : \quad A, B, n_a, n_b$$

$$M\ 3 \quad T \rightarrow B : \quad A, B, n_b, k_{ab}, \quad A, B, n_a, k_{ab} \quad k_a \quad k_b$$

$$M\ 4 \quad B \rightarrow A : \quad A, B, n_a, k_{ab} \quad k_a, \quad A, B \quad k_{ab}$$

$$M\ 5 \quad A \rightarrow B : \quad B, A \quad k_{ab}$$

SICUREZZA NELLE RETI

APPELLO DEL 01 FEBBRAIO 2010

Esercizio 1

punti: 10

La modalità CBC: schema, propagazione dell'errore e vantaggi rispetto alla modalità ECB.

Esercizio 2

punti: 12

I processi A e B dispongono solo di un cifrario a chiave pubblica e di un cifrario a chiave simmetrica. Si assuma che A conosca la chiave pubblica Π_b di B e viceversa. Progettare per mezzo della logica BAN un protocollo di distribuzione delle chiavi che soddisfi i seguenti requisiti

1. A ha la prova che B dispone della chiave di sessione K_{ab} e viceversa;
2. i clock non sono sincronizzati;
3. il protocollo è resistente ad attacchi di replay;
4. la chiave di sessione è generata da uno dei due processi.

Modificare il protocollo assumendo che entrambi i processi contribuiscano alla generazione della chiave di sessione.

Esercizio 3

punti: 8

Il problema della delega in Kerberos e le relative soluzioni.

Soluzione

Esercizio 2

$$M1 \quad A \rightarrow B: \quad K_a \Pi_b$$

$$M2 \quad B \rightarrow A: \quad K_a, K_{ab} \Pi_a$$

$$M3 \quad A \rightarrow B: \quad A, B_{K_{ab}}$$

$$M1 \quad A \rightarrow B: \quad K_a \Pi_b$$

$$M2 \quad B \rightarrow A: \quad K_a, K_b \Pi_a$$

$$M3 \quad A \rightarrow B: \quad K_b, K_a \Pi_b$$

$$M4 \quad B \rightarrow A: \quad A, B_{K_{ab}}$$

$$M5 \quad A \rightarrow B: \quad B, A_{K_{ab}}$$

Nome e Cognome _____ Matricola _____

ESERCIZIO 1

Punti:6

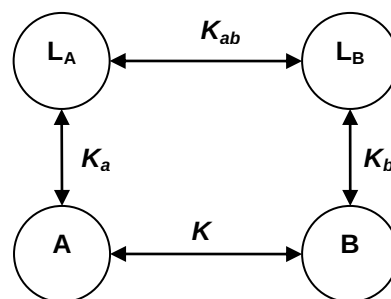
Con proprietà di linguaggio e precisione matematica, il candidato

- enunci le proprietà di *preimage resistance*, *2nd-preimage resistance* e *collision resistance* di una funzione hash sicura;
- ne discuta la rilevanza rispetto alla firma digitale; ed
- indichi il limite superiore della sicurezza (in termini di complessità) di una funzione hash con m bit di output.

ESERCIZIO 2

punti: 14

Due soggetti A e B stabiliscono una chiave di sessione K utilizzando il protocollo Diffie-Hellmann con parametri pubblici p e g . Al fine di evitare il MIM-attack, essi usano un sistema di certificazione online riportato in figura. Ogni soggetto fa riferimento ad una autorità di certificazione locale (ad esempio L_A) ed ha con essa una relazione di fiducia che si concretizza nella condivisione di una chiave segreta (ad esempio K_a). L'autorità di certificazione ne certifica il parametro pubblico (Ad esempio L_A certifica il parametro pubblico X_A di A). Tra le autorità di certificazione locali esiste una cross-certificazione che si concretizza nella condivisione di una chiave segreta (ad esempio K_{ab}).



Usando la logica BAN, il candidato progetti e verifichi il protocollo completo di autenticazione e definizione di una chiave di sessione tra i soggetti A e B sia nel caso in cui i clock non sono sincronizzati sia in quello in cui lo sono. Nel secondo caso, si assuma che il certificato abbia una validità di D unità di tempo.

ESERCIZIO 3

punti:8

Con proprietà di linguaggio il candidato descriva il meccanismo a finestra anti-replay di IpSec.

Soluzione

ESERCIZIO 1

Vedi appunti.

ESERCIZIO 2

Senza clock sincronizzati

- M1. A -> B: Na
- M2. B->LB: {Na, XB}Kb
- M3. LB->LA: {Na, XB}Kab
- M4. LA->A: {Na, XB}Ka

Parallelamente a questi msg ci sono quelli M1'-M4' per la certificazione di A rispetto a B. Il protocollo si ottiene sostituendo A con B.

Con i clock sincronizzati

- M1. A->LA: {tA, XA}Ka
- M2. LA->LB: {tA, XA}Ka
- M3. LB->B: {tA, XA}Kb

Parallelamente a questi msg ci sono quelli M1'-M3' per la certificazione di A rispetto a B. Il protocollo si ottiene sostituendo A con B.

ESERCIZIO 3

Vedi appunti.

Nome e Cognome _____ Matricola _____

ESERCIZIO 1

Punti: 10

Lo schema di cifratura RSA e la sua relazione con il problema della fattorizzazione.

ESERCIZIO 2

punti: 10

In un sistema cliente servitore, si consideri il seguente protocollo di autenticazione tra il server S ed un cliente C :

M1 $C \rightarrow S$: "Hello", C	Legenda a. $C_A(S)$ denota il certificato rilasciato al server S dall'autorità A di cui S e C si fidano (si assuma che la chiave pubblica di A sia ben nota); b. $\mathcal{P}_S(x)$ denota la cifratura della quantità x con la chiave pubblica di S ; c. K denota una chiave segreta generata da C ad ogni nuova sessione; d. $\mathcal{E}_K(x)$ denota la cifratura della quantità x con la chiave simmetrica K ; e. n denota un numero random generato da C ad ogni nuova sessione; ed infine f. PWD denota la password di C memorizzata sul server S .
M2 $S \rightarrow C$: $C_A(S)$	
M3 $C \rightarrow S$: $\mathcal{P}_S(K, C), \mathcal{E}_K(n)$	
M4 $S \rightarrow C$: n	
M5 $C \rightarrow S$: $\mathcal{E}_K(C, PWD)$	
M6 $S \rightarrow C$: $\mathcal{E}_K("OK")$	

Domanda a. Al termine del protocollo, il cliente C può ritenere di stare effettivamente interagendo con il server S ? Motivare la risposta.

Domanda b. Al termine del protocollo, il server S può ritenere di stare effettivamente interagendo con il cliente C ? Motivare la risposta.

Domanda c. Al termine del protocollo, la chiave K può essere utilizzata per garantire la segretezza della sessione tra S e C . Motivare questa affermazione rispetto alla presenza di un avversario passivo.

ESERCIZIO 3

punti: 10

Con riferimento al sistema Kerberos, il candidato illustri il protocollo base, discuta le ipotesi sotto le quali il protocollo di autenticazione è sicuro, discuta il dimensionamento delle finestre temporali.

Nome e Cognome _____ Matricola _____

ESERCIZIO 1

Punti: 10

Con proprietà di linguaggio e precisione matematica, il candidato definisca un cifrario perfetto secondo la teoria di Shannon. Inoltre, il candidato dimostri che a) in un cifrario perfetto il numero di chiavi non può essere inferiore al numero dei messaggi; e che b) un cifrario asimmetrico può essere sicuro solo da un punto di vista computazionale.

ESERCIZIO 2

punti: 10

I processi A e B utilizzano un cifrario simmetrico $E()$ ed una funzione hash con chiave $h_k()$. A e B condividono le chiavi segrete K_e e K_a da utilizzare con E ed h rispettivamente. Infine A e B utilizzano un servizio anti-replay basato su di un meccanismo contatore-finestra (come quello di IPsec). Supponendo che il formato dei messaggi sia $\langle ciphertext, counter, mac \rangle$, con $counter$ valore del contatore del mittente, specificare quale, o quali, dei seguenti schemi fornisce il servizio anti-replay:

1. $ciphertext = E(K_e, m); mac = h(K_a, counter)$
2. $ciphertext = E(K_e, m || counter); mac = h(K_a, counter)$
3. $ciphertext = E(K_e, m); mac = h(K_a, ciphertext || counter)$
4. $ciphertext = E(K_e, m); mac = h(K_a, m)$
5. $ciphertext = E(K_e, m || h(K_a, m)); mac = h(K_a, counter)$

ESERCIZIO 3

punti: 10

Con proprietà di linguaggio e precisione matematica, il candidato descriva il protocollo WEP. Il candidato discuta anche il *key reuse attack* a cui WEP è soggetto.

Appello del 3 febbraio 2012

NOME E COGNOME _____ MATRICOLA _____

ESERCIZIO 1

punti:10

Con proprietà di linguaggio e precisione matematica, il candidato i) descriva l'algoritmo di cifratura, decifratura e generazione delle chiavi RSA. Inoltre, ii) illustri la dipendenza delle prestazioni di cifratura/decifratura dalla configurazione dei bit della chiave.

ESERCIZIO 2

punti: 12

A) Si progetti un protocollo di distribuzione delle chiavi in *due fasi* basato su Diffie-Hellmann con parametri pubblici p e g specificato come segue. Nella prima fase, A e B fanno certificare il proprio parametro pubblico alla terza entità fidata T . Tale certificazione ha un *periodo di validità* pari a Δ secondi. Nella seconda fase, A e B interagiscono tra di loro e stabiliscono una *chiave di sessione* K_{AB} . Nella progettazione si assuma che: i) i clock siano sincronizzati; ii) A e B condividano con T le chiavi simmetriche K_A e K_B rispettivamente. B) Si analizzi il protocollo verificando se esso soddisfa la proprietà $A \stackrel{X_B}{\models} B$ e $B \stackrel{X_A}{\models} A$. Inoltre, C) si specifichino quali controlli deve fare ciascun partner nella Fase II per verificare se il parametro pubblico è valido.

ESERCIZIO 3

punti:5

Con proprietà di linguaggio e precisione matematica, il candidato illustri l'attacco *common modulus*.

Appello del 3 febbraio 2012

NOME E COGNOME _____ MATRICOLA _____

Soluzione

ESERCIZIO 1

Vedi appunti.

ESERCIZIO 2

A) Si progetti un protocollo di distribuzione delle chiavi in *due fasi* basato su Diffie-Hellmann con parametri pubblici p e g specificato come segue. Nella prima fase, A e B fanno certificare il proprio parametro pubblico alla terza entità fidata T . Tale certificazione ha un *periodo di validità* pari a Δ secondi. Nella seconda fase, A e B interagiscono tra di loro e stabiliscono una *chiave di sessione* K_{AB} . Nella progettazione si assuma che: i) i clock siano sincronizzati; ii) A e B condividano con T le chiavi simmetriche K_A e K_B rispettivamente. **B)** Si analizzi il protocollo verificando se esso soddisfa la proprietà $A \models \overset{X_B}{\vdash} B$ e $B \models \overset{X_A}{\vdash} A$. Inoltre, **C)** si specifichino quali controlli deve fare ciascun partner nella Fase II per verificare se il parametro pubblico è valido.

Soluzione

Domanda A)

FASE I

Il seguente protocollo permette ad A di certificare il proprio parametro pubblico X_A

$$M1 \quad A \rightarrow T: \left\{ A, X_A, t_A, \Delta \right\}_{K_A}$$

$$M2 \quad T \rightarrow A: \left\{ A, X_A, t_{AT}, \Delta \right\}_{K_B}$$

Un protocollo analogo per B si ottiene sostituendo A con B e viceversa.

FASE II

$$M3 \quad A \rightarrow B: \quad A, X_A, \{A, X_A, t_{AT}, \Delta\}_{K_B}$$

$$M4 \quad B \rightarrow A: \quad B, X_B, \{B, X_B, t_{BT}, \Delta\}_{K_A}$$

Domanda B)

Ipotesi

- | | |
|--|---|
| 1. $A \models A \leftrightarrow T^{K_A}$ | 7. $B \models \#(t_{AT})$ |
| 2. $B \models B \leftrightarrow T^{K_B}$ | 8. $B \models T \Rightarrow A \models \mapsto A^{X_A}$ |
| 3. $A \models \mapsto A^{X_A}$ | 9. $B \models A \Rightarrow \mapsto A^{X_A}$ |
| 4. $A \models \mapsto A^{X_A}$ | 10. $A \models \#(t_{BT})$ |
| 5. $T \models \#(t_A)$ | 11. $A \models T \Rightarrow B \models \mapsto B^{X_B}$ |
| 6. $T \models \#(t_B)$ | 12. $A \models B \Rightarrow \mapsto B^{X_B}$ |

Alla ricezione del messaggio M1, in virtù delle ipotesi 1) e 5), $T \models A \models \mapsto A^{X_A}$.

Conseguentemente M2 (e quindi M3) può essere idealizzato come $\left\{ t_{AT}, \Delta, A \models \mapsto A^{X_A} \right\}_{K_B}$. Alla

ricezione di M3, in virtù di 2, 7, 8 e 9, si ha $B \models \mapsto A^{X_A}$.

Ragionamento analogo vale per A.

Domanda C)

Sia t l'istante a cui B riceve M3. Il parametro pubblico X_A è valido se $t \leq t_{AT} + \Delta$.

ESERCIZIO 3

Vedi appunti.